GDPR: A Technical Evaluation for Determining an “Adequate Level of Protection”

Emilio Bottiglia

May 2018

Individual Project

Submitted in part fulfilment for the degree of

B.Sc. (Hons) Digital Forensics and Cyber Security

School of Informatics and Engineering,
Institute of Technology Blanchardstown,
Dublin, Ireland

Declaration

I hereby certify that this material, which I now submit for assessment on the programme of study leading to the award of Degree of **B.Sc. (Hons) Digital Forensics and Cyber Security** in the Institute of Technology Blanchardstown, is entirely my own work except where otherwise stated, and has not been submitted for assessment for an academic purpose at this or any other academic institution other than in partial fulfilment of the requirements of that stated above.

Signed: Emilio Bottiglia Dated: 13/05/2018

Abstract

The new GDPR that come into effect on May 25th, requires organisations to do an initial data mapping as a first step towards compliance. In addition, companies need to provide an "adequate level of protection" to data subject. Nevertheless, "adequate" is no further defined and is open to personal interpretation. The aim of this project is give a practical meaning to the "adequate level of protection" and provide firms with an application for data mapping.

An investigation is carried out taking as a reference celticShoes.ie, a hypothetical e-commerce based in Ireland. Boundaries of this organisation, both physical and virtual (e.g. biometric devices to access the building, cloud server, phishing attacks, just to name a few) are explored with emphasis on vulnerabilities that could pose data subject at risk. The project will then give a brief explanation of why that particular technology is a threat and how to patch it to provide an "adequate level of protection". With regard of data mapping, the project will develop a Python file scanner application. Given a specific folder, the application will scan the latter seeking for text files (txt, pdf, docx, xslx, csv) and will read each of them. Each file is then compared with words sensible for the GDPR and a final report in csv form is provided to the user. The report will have in the first column the list of files scanned and next columns list of sensible words found in it.

The result is a technical evaluation that will help those organisations that are working towards compliance or just approached the GDPR, to become aware of what risks are involved in handling data subject and have an idea of some of the changes they need to provide an acceptable level of compliance. In addition, firms will have an opportunity to perform an initial data mapping that is the first step towards compliance by using the Python application GdprSafe v1.0. Easy to use (command line), the application provide a report by which organisation can have a clear view of what kind of files they have in their workstation/servers that need to be properly protected for GDPR purposes and who in the organisation can access it.

Contents

CHAPTER 1: INTRODUCTION.....7

1.1 BACKGROUND 7
1.2 PROBLEM DEFINITION.....7
1.3 HYPOTHESIS 8
1.4 OBJECTIVE.....8
1.5 SUMMARY OF CHAPTERS 8

CHAPTER 2: PREVIOUS LEGISLATION.....10

2.1 EU DATA PROTECTION DIRECTIVE (95/46/EC) 10
2.2 DIRECTIVE AND CLOUD COMPUTING.....12
2.3 FRAMEWORK DECISION 2008/977/JHA.....12
2.4 CONCLUSION 13

CHAPTER 3: GENERAL DATA PROTECTION REGULATION (GDPR).....14

3.1 WHAT IS GDPR?.....14
3.2 PRINCIPLES OF GDPR 14
3.3 MAIN CHANGES OF GDPR 15
3.3.1 One stop shop.....15
3.3.2 Non-EU organisations.....15
3.3.3 Type of data protected.....15
3.3.4 Data breaches report.....16
3.3.5 Special categories of personal data.....16
3.3.6 Children data.....16
3.4 NEW ROLES AND RESPONSIBILITIES.....17
3.4.1 Data Processor 17
3.4.2 Data controller.....17
3.4.3 Data Protection Officer (DPO).....17
3.5 GDPR AND TECHNOLOGY 18
3.5.1 Biometric data.....18
3.5.2 GDPR and Cloud Computing 18
3.6 IMPACT OF GDPR ON SCIENTIFIC RESEARCH 19
3.7 SANCTIONS UNDER GDPR.....19

CHAPTER 4: COMPARISON GDPR - EU DIRECTIVE.....21

4.1 CONCLUSION 23

CHAPTER 5: OVERVIEW OF THE CIA TRIAD 25

CHAPTER 6: BUSINESS CASE: CELTICSHOES.IE 28

6.1 BIOMETRICS.....29
6.1.1 Overview.....29

6.1.2 Best practices *33*
6.2 BRING YOUR OWN DEVICE (BYOD) 34
6.2.1 Overview *34*
6.2.2 Best practises *36*
6.3 CUSTOMER SERVICE 38
6.3.1 Overview *38*
6.3.2 Social engineering *39*
6.3.3 Phishing analysis *40*
6.3.4 Best practises *45*
6.4 CORPORATE NETWORK 46
6.4.1 Overview *46*
6.4.2 Best practises *48*
6.5 CLOUD SERVER AND THE INTERNET 49
6.5.1 Overview *49*
6.5.2 Best practises *53*
6.6 INSIDER THREAT 56
6.6.1 Overview *56*
6.6.2 Best practises *58*
6.7 DATA ENCRYPTION 59

CHAPTER 7: COMPARISON WITH BANKING SITE 60

7.1 ONLINE BANKING U-BANK.COM 60
7.1.1 Overview *60*
7.1.2 Comparison *61*

CHAPTER 8: PYTHON APPLICATION FOR DATA MAPPING 64

8.1 OVERVIEW 64
8.2 SYSTEM ANALYSIS AND DESIGN 64
8.2.1 System requirements *65*
8.2.2 Design *66*
8.2.3 Implementation *66*
8.2.4 Testing *67*
8.2.5 Maintenance and evolution *69*

CHAPTER 9: CONCLUSION 70

APPENDIX A: GLOSSARY 71

LIST OF REFERENCES 73

Chapter 1: Introduction

1.1 Background

Data privacy in the EU has recently done a big step with the implementation of the GDPR that will come into effect on 25th May 2018. Before that, the EU Data Protection Directive (95/46/EC) marked the landscape for several years and was the main reference among EU state members. It was the conclusion of an EU project to create some rules to complement the movement of personal information, the freedom of the individual and protection of their fundamental rights.

Although EU Directive was something applied to EU countries, each single nation had to implement it locally and harmonise with their local legislation. This appeared immediately one of the main obstacles since some countries took years before having it implemented and, in some cases, it was never fully applied. In addition, the aim of the Directive was to create rules to process data in computerised databases and missed to consider the big picture of a cyber world growing exponentially.

First big change the GDPR introduces is while Directive needed to be implemented in local legislations, the GDPR is directly applied to all EU countries on 25th May 2018. In addition, overseas organisations that collect data of EU individuals are also expected to obey the GDPR. New categories of data are now protected, and this includes digital IDs (Web data such as location, IP address, cookie data and RFID tags) and biometric data.

Another important change is definition of child which is considered a person with the age or below 15 (although member states have flexibility to adjust this limit between 13 and 16). Any communication addressed to children need to be clear and in a language the child easily understands.

With regard of sanctions, organisations now face up to €20 million fine for basic data protection violation and up to €10 million for breaches of obligation of the data controller.

1.2 Problem definition

The GDPR document mentions is some places that an “adequate level of protection” is necessary to make sure an individual data is properly protected and used only for the purpose it was collected. But “adequate” is nowhere further addressed and leave an open door to a personal interpretation.

GDPR is considered a big business since requires organisations to obey strict rules to avoid expensive fines and damage in reputation. There are out there many security organisations that have prepared to become a GDPR consultants and offer their help to comply with the legislation. There is no comprehensive documentation on this topic therefore requirements are not clear.

The aim of this project is to evaluate "adequate" and try to answer questions such as what "adequate level of protection" means? and "what is required from an organisation's IT infrastructure to meet that adequate level of protection"? Although the GDPR is particularly meticulous in defining data subjects and boundary of protection, this project will try to further expand the above topics and fill the gap.

In addition, since data mapping is the first step organisations need to undertake towards compliance, this project will also develop a python application to help organisation understand what kind of data they store that is protected under GDPR.

1.3 Hypothesis

GDPR main aims is to make sure data is collected and used only for the purpose the user gave consent and properly secured. With regard of data security and its "adequate level of protection", a hypothesis that could be done at this early stage is data leaking could occur for two main reasons: directly (someone in the organisation intentionally steal data); indirectly (a hacker get access the organisation network or an employee involuntarily send some sensible data to the wrong person). Consequently, it is likely firms will need to go through an IT audit process as well as consider a review of their workforce.

1.4 Objective

The objective of this research is to analyse hypothesis and give it a practical meaning by creating a model of an IT infrastructure that could resemble a today medium/small online organisation. An investigation is then carried out through boundaries, both on line and physical, to understand some of the vulnerabilities specific to devices/technologies that could pose data subject at risk, explain why it is a threat and what is required to reach an "adequate level of protection". This evaluation will help those organisations that have not taken any step as well as those that are some steps ahead towards compliance, to become aware of some of the risks originating from technologies they may have been using from years. In additions, this document will benefit those business owners that have little or no knowledge of IT at all, to have a basic understanding of those technologies thus gaining a deeper view of the implications they may have with regard of GDPR.

1.5 Summary of chapters

Chapter 2 introduces the EU Data Protection Directive (with a brief overview of the Framework Decision 2008/977/JHA regarding protection of personal data for police and criminal matters) and shows how this was inadequate for our technological era. Chapter 3 goes through the new GDPR changes introduced respect to the directive and chapter 4 compares changes with a final table summarising main differences. Chapter 5 explain the importance of the CIA triad (the 3 pillars of communication) while chapter 6 introduces the use case of celticShoes.ie, a small online e-

commerce used to investigate boundaries vulnerabilities. Chapter 7 is about a comparison with a large organisation (banking site) to have an overview of what are the different requirements when a highest level of security is required. Chapter 8 explain the functionalities of GdprSafe v1.0, a python application for data mapping to help organisations understand what kind of data sensible for GDPR purposes they store and where.

Chapter 2: Previous Legislation

2.1 EU Data Protection Directive (95/46/EC)

EU Data Protection Directive (95/46/EC) (Directive) was the culmination of the ambitious project of the EU to implement an internal market related to movement of personal information combined with the freedom of the individual and the protection of his fundamental rights (Commission of the European Communities, 2003).

According to Article 4, the Directive applies to individual or organisations that reside in an EU state. For instance, if the data controller resides in France the national French data protection law applies (Wong 2012). However, this arose some concerns. For instance, as mentioned in (Wong 2012) "Whilst it gives some certainty over the law to be applied, it raises several problems. If an online user (X) from country A purchases items from a data controller who is based in country B, the data protection laws of B would apply. To amplify the example, the data. controller has suffered from a data security breach resulting in the loss of personal information including data belonging to X. Although the data protection laws of B apply, yet recourse or remedy would be difficult in practice to apply without X having first to com- plain to the data controller in the first instance. If this fails, then the next step would be either to complain to X's own Data Protection Commissioner in X's own country or instigate legal proceedings against the data controller (based in country B) in the event of a data security breach for an appropriate remedy. This illustrates the complexities of the data protection law and the administrative hurdles that exist for a data subject to seek further recompense" (Commission of the European Communities, 2003). EU directive is something that had to be implemented locally in each country by transposing the directive into national law. However, local implementations took several months and in some cases years. Five countries (Ireland, Luxembourg, France, Germany and Netherlands) were demanded to the European Court of Justice in 1999 by the commission because they failed to implement the directive locally. Among those countries Ireland only notified a limited implementation in 2001, namely six years after the directive took place. There were some initial difficulties in implementation, the Directive achieved his goal of the free movement of personal data among member states. Initially the main concern was that only some of the states had already something similar implemented locally and some like Italy and Greece had nothing. However, the latter were the first to adopt it upon its implementation. Since then, the commission had no complaints with regard to the refusal of protection of personal data transferred between state members (Commission of the European Communities, 2003).

The directive was initially created to cope with processing of data subject contained in computerised databases. In the proceedings of the "First report on the implementation of the Data Protection Directive (95/46/EC)" that was a requirement in Article 33 of EC Directive 95/46, it

becomes clear that due to exponential advancements in technologies, there were increasingly businesses and domestic devices connected to the internet. This led to a large amount of personal data being collected and exchanged every day with often sophisticated and undetectable means such as CCTV, spyware installed on PCs to monitor and collect users' activity, employees monitoring in the workplace etc. Even personal information like browsing habits, was and is nowadays sold to third parties often without our knowledge. For these reasons, concern was raised about the 95/46 directive, which was in the position to effectively manage this challenge in particular with regard of unlimited geographical barriers opened by the internet (Wong 2012).

This was further discussed in by Bessant (2015) considering the case of photographs posted online without the consent of the individual. The case study refers to UK parents taking pictures of children, often in groups. While this was not an issue decade ago with printed pictures stored in physical albums, the advent and widespread use of the internet has changed this landscape, with pictures, for the greater part digitally stored online. The concern is when pictures are taken in group and the parent photographer does not ask permission of parents of other children in the picture to have those photographs posted online.

Directive 95/46 seems to leave a high degree of interpretation and confirms that it was not ready for the digital age when approved. In particular, section 36 of the Data Protection Act (DPA) that incorporates article 3(2) of the directive states, "'Personal data processed by an individual only for the purposes of that individual's personal, family or household affairs (including recreational purposes) are exempt from the data protection principles and the provisions of Parts II and III.' For the above case study, if the parent is considered taking and posting children pictures online for personal purposes, in this case article 36 would not apply and there would be no obligation to ask consent to the other children involved to have their picture shared for instance on Facebook (Bessant 2015).

This was not the case for instance in the Lindqvist case in Sweden. In 2005 Ms Lindqvist, a catechist working for the Swedish Protestant Church, posted on a personal website details of her colleagues. The case was brought to the attention of the European Court of Justice (ECJ) from a friend of Ms Lindqvist that was not happy about having her personal information published online. While Ms Lindqvist argued her practises were for personal and not business purposes therefore exempted by article 3(2), the ECJ rejected this claim and found Ms Lindqvist infringed the directive. This verdict definitely dissolved any doubt on the direction the ECJ had taken at that time (Harris 2007).

To cope with the aforementioned changes in technologies, there were two amendments to address the telecommunication sector: Directive 97/66/EC and 2002/58/EC (Commission of the European Communities, 2003).

2.2 Directive and Cloud Computing

Cloud computing has revealed as one of the most prominent advances in technology that has revolutionised the world by abolishing barriers and the way organisations conduct their businesses, bringing significant advantages and benefits to our lives but also creating additional concerns in matter of privacy and personal data subject. According to Hon et al. (2011), the directive is not practical to be applied to cloud computing and states cloud providers should not be liable under the new directive since considered they are only intermediary and are not directly involved in data protection obligations. On the other hand, Poullet et al. (2011) states that "Cloud computing seems closer to fog than cloud and it might constitute a real danger for the users and data subjects whoever they are (legal entities, individuals). To create this state of uncertainty is the fact authors see cloud computing as way to lose control of data that are somewhere in the cloud. Authors also argue if cloud providers could be considered data controller under the directive.

Mantellero A. (2012) argues that in the cloud provider - final user relationship, the first take the role of processor while the latter of the controller. This because only the final user can process data while the cloud provider only receives information and execute it on behalf of the user. To add an example on how Mantellero's view materialised, there is the case of the European Court of Justice (2014) that gave mandate to google to remove personal data from the result of its search engine. In particular, in 2010 a Spanish citizen complained to the Spanish data protection agency that a user inputting his details in Google received a link to newspaper articles about a foreclosure auction on his home. The court interpreted the search engines operator as data processors and they were imposed to remove data subject. This is because data is primarily collected, then retrieved and recorded in servers. An important point in this issue was that although Google data is perhaps stored overseas, the search resulted in the Spanish website of the cloud giant therefore in the EU jurisdiction of the directive.

2.3 Framework Decision 2008/977/JHA

Published in December 2008 after 2 consultations in 2006 and 2007 respectively, the Framework Decision was an important document regarding protection of personal data for police and criminal matters among EU member states. In particular the Framework was created with the goal to provide a high level of protection to personal data for those subjects involved in criminal matters when for instance for the purpose of investigation, was necessary transmission of personal data among members states.

In line with the Directive, the framework insured personal data to be processed only for the initial scope it was collected and a further procession would have been done only for the following purposes (Council Framework Decision 2008/977/JHA):

- To prevent an immediate threat to public security
- For the investigation and prevention of offences different from the ones initially alleged
- Other purposes explicitly approved from the data subject
- Statistical and scientific purposes provided the member state make data anonymous

It is clear that the Framework Decision scope was two folded: firstly, protect public interest and safety by fomenting cooperation among member states and secondly protecting personal data processed for criminal and jurisdictional purposes. In addition to the Directive, the framework ensured properly policy for the transmission of data to overseas countries and not only among authorities of member states (Nino 2010).

2.4 Conclusion

Summarising, the Directive can be considered a milestone for the time it was provisioned for the harmonisation among EU state members in relation of personal data subject protection. Although agreed among state members, each single state had to transpose it into local legislation to become national law and this caused some initial delays in certain countries due to different reason such as the lack of any previous legislation on this matter or contrast and collision with different internal regulations. Despite all countries had it implemented, it soon became clear exponential advances in technology created some gaps and made it almost redundant for the current "online" technological age.

Chapter 3: General Data Protection Regulation (GDPR)

3.1 What is GDPR?

GDPR is the new data protection regulation that will be enforced upon the 28 EU member states on 25th May 2018.

In the previous EU Data Protection Directive (95/46/EC), there were different levels of protection mainly caused by the fact each state had different procedure and data protection laws. This caused some fragmentation over the EU and those differences were an obstacle with regarding the free flow of personal data across the European Community (Van Eecke 2017).

The objective of GDPR is to level out the existing legal structure. While the current Directive is adapted to each state based on their internal legal structure, regulation is applied directly and uniformly in the EU member states. In addition, GDPR brings a relief with regards to compliance for organisations that have a presence in multiple EU states and reduce cost and administrative burden (Van Eecke 2017).

In addition to regulating data protection in the EU member states, GDPR also dictates movement and export of data outside the EU, for instance, for those organisations that have a presence overseas but still process data belonging to EU residents.

3.2 Principles of GDPR

Differently from the Data Protection Directive, accountability plays an important role in the GDPR since organisations need now document and show how they observe it. According to Chapter II, Article 5, "Principles relating to processing of personal data" of the GDPR (Intersoft Consulting n.d.), personal data should be:

1. Processed in a fairly and transparent manner
2. Collected for limited purposes and if it needs to be further processed, the new purpose does not need to be incompatible with the initial scope.
3. Limited to only what is relevant and necessary with regards to its purpose
4. Accurate in terms of the reasons as to why it was collected. If this is not the case, data should be corrected or erased
5. Retained in a way that allows subject identification strictly for the time necessary to accomplish this task then encrypted or erased
6. Kept intact and confidential during processing against unauthorised access or illegal processing.

According to Chapter II, Art 6, Paragraph 4, it is worth noticing with regards to point 2, when data processing is different from the initial purpose for which data subject gave consent, the controller should verify if the new purpose is compatible with the initial one (Intersoft Consulting n.d.). The data controller should:

- Take into account connections between the initial purpose and the new one
- Analyse the link between the controller and the data subject at the time data was collected
- What kind data is being processed to verify if any special category is involved
- Measures in place for proper security like encryption and pseudonymising

3.3 Main changes of GDPR

3.3.1 One stop shop

Organisations that have multiple presence across the EU, have now less burden and the compliance process should be simplified. A main establishment in one of the EU states will now take the role of a Supervising Authority (SA) with duties of data processing for the entire organisation.

3.3.2 Non-EU organisations

Any organisation not established in EU but that processes data of EU residents, will need to comply with GDPR regulation. This will require many overseas organisations to review, plan and assess their compliance to obey the regulation to avoid fines (Van Eecke 2017).

3.3.3 Type of data protected

Article 4 of GDPR states: "personal data' means any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person" (Van Eecke 2017). Thus, main difference is now other than usual personal data such as name, ID and address, an introduction of online and electronic identifiers such as IP or an RFID tag plus biometric and genetic data. The list of data protected is as following (Nadeau 2016):

- Web data like location, IP address, cookie data and RFID tags
- Identity information such as name, address and IDs
- Health and genetic data
- Biometric data
- Racial or ethnic data
- Political opinions
- Sexual orientation

3.3.4 Data breaches report

According to Article 33, any data breaches will need to be reported by the data controller no later than 72 hours to the supervisory authority. If there are any delay in the notification, the data controller will need to justify such delay. The reporting communication should be structured as following:

- Contains details such as nature of data, categories involved and number of data records
- Effect of data breaches
- Mitigation and countermeasures to contain data breach
- Documentation with details of the data breach event and mitigation will need to be provided by the controller to the supervisory authority that will confirm compliance with the Article 33

3.3.5 Special categories of personal data

Article 9 of GDPR (Intersoft Consulting, n.d.) defines special categories of personal data as "data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health or data concerning a natural person's sex life or sexual orientation" and states this data processing should be prohibited.

There are conditions under by which this special category of data can be processed for example the data subject has given consent or the processing is for the purpose of unemployment or social security for which the data controller is carrying out his rights or duties.

Particular situations such as assessment of work capacity of the subject, medical diagnosis, social care, legal implications like legal claims for and against the subject or the data subject is not in the capable conditions to give consent, are exceptional circumstances under which this kind of data can be processed.

3.3.6 Children data

Special attention is dedicated to children data whom due to the early age, may not be aware of the risks involved. The main provisions of GDPR on this matter are mainly related to the age restriction for giving consent and different language for consensus request:

- Consent age. A person of the age or above 16 is no longer considered a child. Some flexibility is given to member states to adjust this limit between 13 and 16. Data controllers must ensure the age of the child and request consent from anyone responsible if the age is below 13.
- Privacy note. Data controllers must ensure the age of the child and provide consensus notices in clear and understandable format for the child.

In additions to the above, children are further mentioned in the GDPR document for those cases where any communication addressed to them "should be in clear and plan language the child can easily understand" (activeMind.legal 2018).

3.4 New roles and responsibilities

For the purpose of compliance, GDPR introduce roles that are responsible for compliance.

3.4.1 Data Processor

Can be an internal figure or an outsourcing organisation. Maintain and process data records taking all measures required in Art. 32 (Intersoft Consulting n.d) that include:

- CIA (Confidentiality, Integrity and Availability) of systems and services as well as pseudonymising and encryption of personal data.
- Restore access to systems and personal data in case of technical issues as well as make sure the organisation has an effective data securing system providing regular testing of the organisation procedures.

3.4.2 Data controller

Look after how data is processed and the purpose by which it is processed, making sure data processing is done in respect of GDPR regulation. In addition, keep records of the processing activity. It is also responsible for compliance of external entities, such as contractors (Article 30).

3.4.3 Data Protection Officer (DPO)

According to Art. 37 of GDPR (Intersoft Consulting n.d.), a DPO must be appointed from Controller and Data Protection officer and is mandatory when the processing of data is carried out by public authorities with the exception of courts and when there is a large/special category amount of data that requires regular monitoring and processing. This new figure reports directly to the highest management. In addition, the DPO needs to undertake tasks in Article 39 that include:

- First point of contact with supervisory authority in case of any accident that involves data processing.
- Responsibility for GDPR compliance including any training of staff involved in the data processing procedure.
- Point of contact for any data subject with regard of any issue for their data processing.
- May undertake other tasks making sure there is no conflict of interest

3.5 GDPR and technology

3.5.1 Biometric data

Art. 4 paragraph 14 defines biometric data as "personal data resulting from specific technical processing relating to the physical, physio- logical or behavioural characteristics of a natural person, which allow or confirm the unique identification of that natural person, such as facial images or dactyloscopic data".

If we think of today common identification systems such as login and password that can be brute-forced trying combinations of thousands of username/password combinations, biometric systems are by principle more secure. For instance, fingerprints are unique bypassing such a system is considerably more difficult.

GDPR pays attention to the use of biometric data. In particular, in the case of biometric data, for instance, used as means of accessing specific information, if the accessed information is less sensitive than the biometric data used, then that an organisation should use a different identification method. If biometric data is used, this means a higher level of security is required when storing those data (Irvin 2017).

3.5.2 GDPR and Cloud Computing

On November 21, 2017, Cloud Security Alliance (CSA), a world leading organisation at the forefront to promote best practises for both cloud providers as well as cloud users, publicised the CSA Code of Conduct (CSA CoC) for GDPR Compliance. This document has the aim to provide guidance for above categories, to comply with GDPR and provides:

- Completeness. Independently of size and location, CSP have guidance on how to comply with GDPR
- Utility. Cloud users can use the tool to measure the level personal data protection offered by a CSP
- Rigor. CSA CoC provide a template to obey to GDPR privacy requirements
- Transparency. Cloud user can have a better understanding of their CSP
- Flexibility. Is applied to any delivery model SaaS-PaaS-IaaS

The CSA CoC handles only the Business-to-Business scenario and addresses two kinds of customer situations:

- the cloud customer is the data "controller" and the CSP is a data "processor"
- both the cloud customer and the CSP are data controllers

In addition, the document offers a guidance to cloud users to evaluate the level of protection offered by different cloud providers.

To further assist cloud users, the CSA opened an online service called GDPR Resource Center available at https://gdpr.cloudsecurityalliance.org/. The service is "community driven" with the goal to instruct cloud service providers and enterprises about the new EU GDPR

3.6 Impact of GDPR on scientific research

Personal data for scientific research assumes a broad meaning within the EU GDPR. According to recitals 159 and 160 of the regulation (Intersoft Consulting n.d.), this includes aspects such as technological development and demonstration, fundamental research, applied research and privately funded research.

An important change introduced by GDPR with respect to the Directive that has had an impact in the field of research, is the revision of the principle related to data integrity and confidentiality. This principle enforces when data is accessed this need to be done in a way to ensure protection against unlawful use or processing and against unintended damage or loss. This principle has particular importance in the field of research, due to the sensitive nature of the data involved and also since data integrity is fundamental in making sure the research is consistent.

Another important step forward brought by the GDPR and welcomed by the scientific community is the introduction and clarification of additional categories of personal data that whose processing is banned but extraordinarily allowed for research purposes in the respect of Articles 9 and 89 of the GDPR. These new categories include data concerning health, genetic and biometric data (Chassang 2017).

3.7 Sanctions under GDPR

With regards to fines and enforcements Article 83 (Intersoft Consulting n.d.) states as follow:

- Violations of basic principle of processing such as consent, data subject right, international transfer or to third parties, will incur in the highest sanctions "up to 20 000 000 EUR, or in the case of an undertaking, up to 4 % of the total worldwide annual turnover of the preceding financial year, whichever is higher "
- Infraction of obligations of controller, certification and monitoring bodies plus data breaches will incur in "fines up to 10 000 000 EUR, or in the case of an undertaking, up to 2 % of the total worldwide annual turnover of the preceding financial year, whichever is higher"

However, still Article 83 mentions any fees can be imposed in addition or replaced by sanctions in Art. 58 that involves as following:

- A notice to controller and processor to make them aware of the potential infringement;

- Remove directly or ask any third-party bodies to withdraw/not issue a certification in case of lack of compliance;
- Command restriction of processing or data deletion or order the controller to communicate a data breach to the subject involved;
- Order a change of direction to controller or processor to back into compliance or temporary/definitive injunction of data processing.

Paragraph 7 of Article 83 mentions something relevant that covers those situations by which for instance if a EU state legal system does not allow fines, the supervising authority may initiate the fine and have it imposed by the national court.

Chapter 4: Comparison GDPR - EU Directive

As seen, GDPR brings a lot of important changes with respect to personal data protection. While the Directive was intended to be locally implemented by members states leading often to data subjects differently processed among the union due to existing local laws and cultures, the GDPR make the directive directly applicable.

The reform has two main aspects:

1. A regulation replacing Directive 95/46/EC. This will ensure people has better control of personal data.
2. A directive replacing Framework Decision 2008/977/JHA. This create rules for protection of personal data processed for criminal, investigative and preventive purposes. This includes not only convicted people but also witnesses and suspect. The directive also ensure personal data for this purpose is properly processed and protected in case of cross-border operation among member states (European Commission 2015).

The below table summarise and compare the main changes between the Directive and GDPR:

Provision	Under Directive	New GDPR
Territorial scope	Non-EU organisations were not implied to apply the Directive when doing business in the EU	Non-EU organisations need to adhere same requirements when doing business in the EU and processing data of an EU resident although they have no branch in the EU
Personal data processing of inaccurate data	Inaccurate data must be deleted or rectified	Add a time constraint: "data must be deleted or rectified without delay"
Data transparency	Implicitly required transparency	Requires data to be processed "in a transparent manner"
Data storage for scientific and statistic purposed	Left members state to decide data storage periods	Exempt this kind of data from the principle "only be kept in identifiable form for no longer than is necessary for the purposes for which they are processed". Instead, allow organisations to store it for more time provided appropriate technical and organisational measures.

Data subject rights	Data subject has right to access, object to processing, transparency, and accuracy	Added: • Right to be forgotten (when an individual does not want their data to be processed anymore, they can ask to be deleted provided there are no grounds to retain it) • Data portability: data subject can request data processor to return data in machine readable format for easier transfer between service providers
Data breaches notifications	No evidence of data breaches to be reported within specific time	Data controller must notify supervisor authority within 72 hours of becoming aware of it.
Sanctions	Members states had to implement sanctions rules locally	Sanctions under GDPR: • For basic data protection violation up to €20 million or 4 percent of an undertaking's total worldwide annual turnover in the preceding financial year, whichever is higher • Breaches of obligations of controller, certification and monitoring bodies plus data breaches: up to €10 million, or in the case of an undertaking, up to 2 % of the total worldwide annual turnover of the preceding financial year, whichever is higher
One stop shop	Company established in multiple EU countries need to obey privacy rules in each country where they are making business	A single member state that take supervisory authority independently of the number of countries the business has established
Type of data protected	Personal data such as ID number, "or to one or more factors specific to his physical, physiological, mental, economic, cultural or social identity"	Added: • Digital IDs: Web data such as location, IP address, cookie data and RFID tags

		• Biometric and genetic data
Data Protection Officer (DPO)	Not mentioned in the Directive	New subject mandatory for organisation when the processing of data is done by public authorities with exclusion of courts and when there is a large/special category amount of data that need to be regularly monitored and processed
Recording of activities	Not mentioned in the Directive	Data controllers have the obligation to keep records of processing activities
Children	Not mentioned in the Directive	• Define child a person with the age or below 15 and give flexibility to member states to adjust this limit between 13 and 16. • Dictate that any communication addressed to children "should be in clear and plain language the child can easily understand"
Application	Directive needed to be integrated into local legislation by each member state	The regulation applies directly to the 28 members states

4.1 Conclusion

This chapter discussed how the exponential growth of advances in technologies in this century was one of the main factors that triggered the need for data protection legislation that encompassed personal data protection for the digital age. Unlike the Directive, the GDPR is applied directly to all members states uniformly, this will ensure there will be no fragmented rules and interpretation in locally in each state.

Similar to EU organisations need to comply with foreign legislation while conducting business abroad, any overseas organisation will now need to comply with the EU if they conduct business locally and process data of EU citizens. In addition, large enterprises that have businesses in multiple EU countries, can now have a centralised supervisory system valid for all EU states.

Additional categories of personal data such as digital IDs, biometric and genetic data have added to the previously Directive list. In addition, special attention is paid to a vulnerable category of people like children.

There is no doubt the GDPR has all the notions to be a successful advance in matter of personal data protection for a large community like the EU provided that any organisation will be ready to comply by May 25, 2018.

Chapter 5: Overview of the CIA triad

Figure 1 - Source: https://bit.ly/2HYt1Hn

Back in the time, communications were limited to traditional methods such as face to face, phone, fax and post. Data was normally stored in paper archives and organisation use to have dedicated rooms in their premises for those purposes. Citizens requesting certificates or applying for services had to walk their way to physical offices, fill in paper forms and get back to office to take their responses or waiting for documentation by post at the latest.

The internet brought a big shift in our lives from what was a world of paper to what is now a digital world. Organisations have now become part of this digital revolution, individuals hardly ever have to walk to public offices but request any documentation directly online, faxes have been replaced by emails, data is not anymore stored in books occupying whole rooms but in small devices such as laptops, hard drives that can be kept in a pocket. Additionally, data may also be stored in remote locations just leasing some digital space and simply download it when needed using our mobile devices (Cloud Computing).

There is no doubt technology has made our life easier so far. However, there is one main downside of it that is the security of exchange of information and how to identify the lost, theft or tampering of digital communication. It is easy for an individual to immediately recognise they lost a physical wallet and asses what was lost or not, but it is difficult if not impossible to understand when a digital wallet has dipped. Anyone nowadays has more or less an amount of personal information stored online both intentionally and unintentionally (think of information collected from online organisations when someone subscribes their services or simply visit their websites).

At the light of the above, is crucial to make sure has much as possible, our online communications and information are securely kept and stored.

The CIA triad represents the three pillars of security. Is a model developed "to guide policies for information security within an organization" (Margaret Rouse 2018).

Confidentiality

Figure 2 - Source: itsecurity.org/what-need-know-cia-triad/

It encompasses those measures and best practises to make sure sensitive information is not disclosed or leaked to the wrong people. Sensitive information is data mentioned in section 3.3.3, a bank account statement, credit card details, PPS number, government data etc. Key point to make sure data confidentiality is encryption.

Integrity

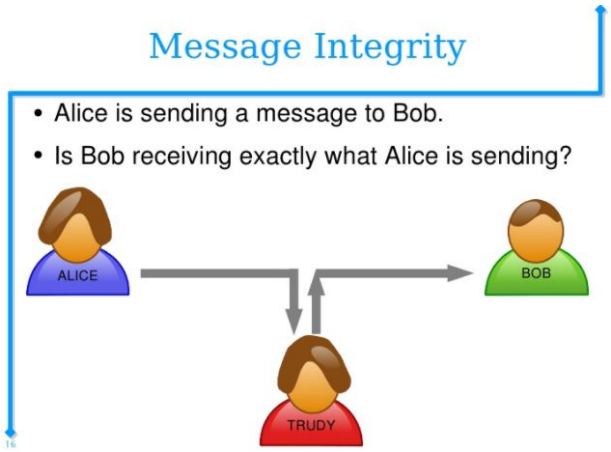


Figure 3 - Source: https://bit.ly/2FMNNYj

It refers to data that is not tampered during transmission and reaches destination is its original format. For instance, if an individual is banking online and requests a transfer to another account of 10 EURO but at the end realises somehow sent 1000 (data tampered along the way), this turn out to be costly to. Digital signature is one of the additional steps that can ensure data is not tampered.

Availability

Figure 4 - Source: itsecurity.org/what-need-know-cia-triad/

Data, systems and resources need to be always available to be useful. Here the damage the company can face is in both loss of sales and reputation in case for instance their website is down. Downtime reasons may be of different nature such as technical (faulty hardware) or intentional (DoS).

There are different ways to ensure availability such as High Availability, provide proper maintenance to avoid hardware failure and backups. Availability techniques are part of a bigger picture defined as Disaster Recovery Plan (DRP). This is a set of rules and policies organisations need to plan carefully that dictate how to react to incidents and bring the system back to work normally in a defined timeframe according to the business priorities.

Figure 5 - DRP lifecycle. Source: https://bit.ly/2HQmgLA

Chapter 6: Business Case: celticShoes.ie

This project uses the case of celticShoes.ie (referred from now on as "the company"), a hypothetical e-commerce small enterprise. It is based in Cork city, it has 15 employees and its business is shipping fashion shoes to customers worldwide that shop on their website.

The company has a main building where employees have access and is divided in three offices and a warehouse from where the product is packed and shipped.

The company infrastructure depicted in figure 1, could resemble a basic requirement found nowadays in an online e-commerce. Depending on the size of the enterprise, there might be additional devices/services:

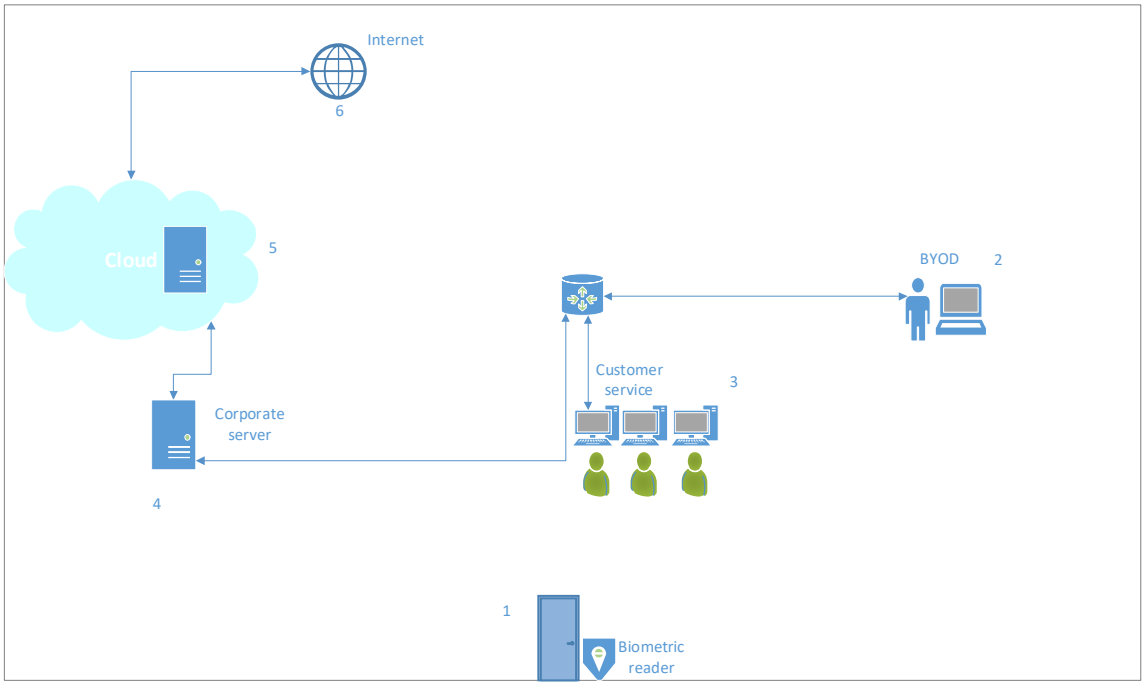


Figure 6 - Sample online e-commerce infrastructure

Follow an overview of each point and relative technologies used:

1. **Biometric reader**. Employees arriving in the morning at the company gain access to the building by face recognition biometric. The camera authenticates and identifies the employee unlocking the door and automatically clocking in.
2. **Bring Your Own Device (BYOD).** The company adopt BYOD policy by which employees can bring their own personal laptops and use for working purposes. It is quite commonplace procedure nowadays and benefits are twofold: on the one hand the company saves money in infrastructure and on the other hand employees feel more comfortable to

work with devices they are familiar with. Additionally, employees have possibility to work from home in some particular circumstances.

3. **Customer service.** The company offer customer support on different channels such as email and phone. Customer service advisors are very friendly at the company and have created a great relationship of trust with customers. As soon as they arrive in the morning they switch on their laptops, check main mailbox and reply to customers queries. Often, clients use to attach images/screenshot to emails to better explain any issue they encounter for instance on the website that help speed up the customer service.
4. **Corporate server.** The company has an internal intranet (a "private" internet to which only employees have access) with organisation information, where employees can communicate and submit their request for instance to HR, check their annual leave allowance. In addition, departments like HR, billing and the management, have access to a restricted area of the intranet with reserved information.

   The corporate server also communicates externally with the web server in a remote location.
5. **Web server.** The company website is hosted on a server in the cloud. Cloud computing is a technology that allow to communicate and store information in a remote location where a device (server) is located. Using a client (for instance web browser like Firefox or Chrome) the final user connects to the server and perform operation like visiting web pages, interact with social media etc. In our specific case, customers of the company can make shopping connecting to their website, add items to the shopping basket, enter payment and shipping detail and finalise the purchase. At this stage order details are forwarded by the system to the billing and shipping department through the corporate server.
6. **Internet.** This is the channel by which the company customers can reach the webserver therefore interacting with the website and customer service.

6.1 Biometrics

6.1.1 Overview

With the latest advances in technology, use of biometrics for individual identification has become commonplace. Every day increasingly public institutions as well as private organisations, have introduced biometrics as a way of identifying people and to prevent frauds, for instance.

Among identifications systems, there are three ways to recognise an individual:

1. Use of biometric data (unique for each person) such as behavioural and physical features of a person (for instance face images);

2. Use of digital keys like PIN or passwords;

3. More traditional systems such as physical IDs (passport, identity cards etc).

Any biometric system process is represented in image 1:

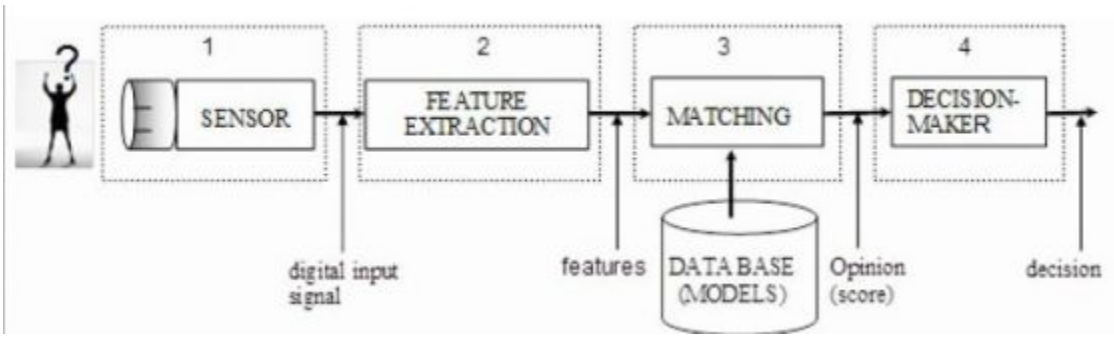


Figure 7 - Biometric system stages. Source: ITB 2017

Biometrics help to authenticate and identify people. Authenticate means "are you who you claim to be?" and it involves a comparison of that person's characteristics to the biometric template stored in a database. Identification involves answering the question "who are you?" by taking a biometric sample of that person such as a fingerprint or face image and compare it with a database of other people (Gemalto 2017).

A key concept for performance of biometric devices is the evaluation of two factors: False Rejection Rate (FRR) and False Acceptance Rate (FAR).

In case of FRR, the biometric device does not recognize biometric data that corresponds to that of a specific person indeed. On the other hand, in case of FAR, the device matches biometric data but it does not relate to the same person. These parameters are calculated as following:

FRR

$$\text{FRR} = \frac{\text{Number of False Rejections}}{\text{Number of Identification Attempts}}$$

Figure 8 - Source: 01- Intoduction to biometrics

FAR

$$\text{FAR} = \frac{\text{Number of False Acceptances}}{\text{Number of Identification Attempts}}$$

Figure 9 - Source: 01- Intoduction to biometrics

These two parameters can be represented on a graph and when they both intersect generate an Equal Error Rate (EER). A lowest value of ERR means the system has good performance.

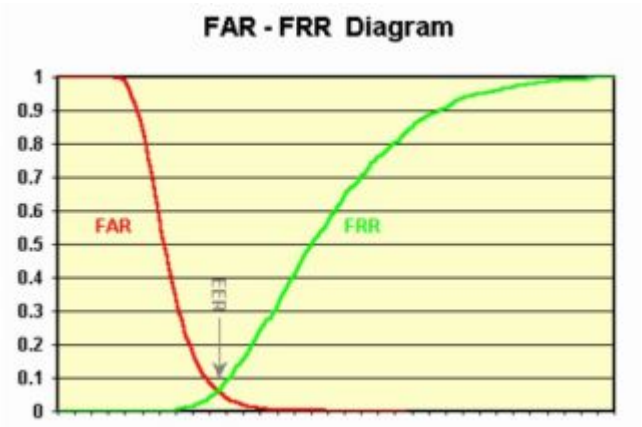


Figure 10 - Source: 01- Introduction to biometrics

The company uses face recognition to allow access to the main building. Among biometrics systems such as fingerprinting or palm reading, face recognition is heavily impacted by the external environment that can have an influence in terms of FRR and FAR. In addition, capturing devices should be of high quality since accurateness of identification depend primarily on the reliability of this implements (Gemalto 2017). Image 1 shows a typical face recognition process (Gemalto 2017):

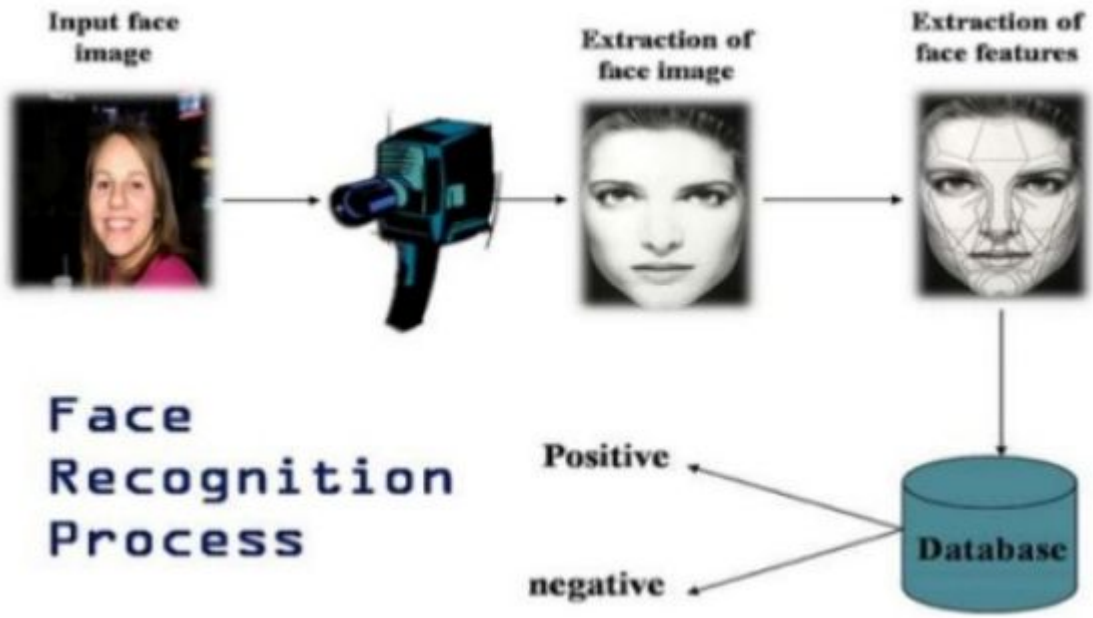


Figure 11 - Face recognitioin process. Source: ITB 2017

The main steps of the above process can be summarised as following:

- Image acquisition. A face is detected from an image or video and extracted
- Face features (nodal points, skin texture analysis) are extracted and used to create a template and store it in a database.
- The new created template is compared with others in the database
- The system finds a match or reject it

Differently from other biometrics technologies such as fingerprint, hand geometry or voice recognition, every human being has a face making this recognition system universally applicable. In addition, although fingerprinting has its own challenges and weaknesses as well, it seems the latter is still treated as more secure compared to face biometric. This is because it is almost impossible to find an individual fingerprint online compared to pictures (see social media like Facebook) that can be used to bypass the system (Armasu 2017).

An example device is in figure 1:

Figure 12 - Face recognition device. Source: sourcesecurity.com

Benefits.

There is no doubt this technology has some benefits such as (Dail 2017):

Accuracy of who is in front of the device. Biometrics devices relies on biological traits that are unique in each person. Therefore, upon registration, when an employee is authenticated and identified, the system can make sure (or at least have a great percentage) the person that is in front the device is who they claim to be.

Avoid access due to a lost ID. Traditional access system such as the use of a badge, may be compromised in case for instance an employee loses their badge. Facial recognition or fingerprinting provide additional security since it is not easily reproduced and individuals always carry with them.

Reduce maintenance costs. While with badges companies need to assign passcodes, issue new badges for new employees and perhaps at some point reprogram it, face recognition readers can help to save considerable amount of money in maintenance and material costs. System upgrades are usually automated software-upgrades that help decrease costs.

Improved customer experience. The system is very easy to use and make employees life at the company even more enjoyable. When they arrive in the morning or back to the building after lunch, there is no need to pull out and swipe their badge. Instead just stand up few seconds in front of the camera and access is granted.

6.1.2 Best practices

Challenges and weaknesses.

Previous section has shown how biometric face recognition have improved employee experience at the company and ultimately also reduce work and costs for the company itself. However, is this technology bullet proof and will allow only real employees to access the company premises? This is not the case since there are yes advantages but also some drawbacks and vulnerabilities.

Facial recognition systems work in two main environments namely controlled and uncontrolled. In the first case, different faces pictures are taken all having the same features for instance same background and pose (frontal or profile). On the other hand, in an uncontrolled environment where the background and surroundings are not the same, people could have different expression or there may be obstacles that partially cover the face. Consequently, samples taken from a facial recognition system in this environment can present challenges.

Accuracy in registration for a capturing device is an important factor since during comparison any small error during the initial phase can result in a matching error. In the same way facial pose such as pan and tilt, can make the difference between a matching and a clashing.

Another factor that could reduce biometric accuracy is the different lighting degree of images in the recognition device. Changes in light could lead to false results since any variance might not necessarily related to a different person but simply to a difference in illumination (Hanna 2017).

Circumvention and countermeasures.

Most common spoofing methods used to bypass the system are for instance, use of images or video that hackers present to recognition 2D cameras. A recent example of exploitation of this system is dated November 9 where a security company from Vietnam bypassed the new iPhone X face authentication system using 3D printed mask build from 2D pictures (Armasu 2017).

A security countermeasure is the use of the liveness 3D technology that companies such as SensibleVision have developed. It consists of devices equipped with 3D cameras that can detect pictures or video instead of a real face. Substantially this system discards any object that does not have the characteristics of a human face. The company claims their system achieve a FAR of 5.11-8 or better and can work in low light (Lee Justin 2017).

This section has shown how face biometric could be bypassed putting a user picture in front of the reader unless the tool used support liveness technology to detect it. It is therefore not advisable to use any of these systems in its own but in conjunction with second factor authentication for added security. Although use of biometrics as added security to an existing PIN or passcode would worsen user experience, something to consider is what the outcome of a security breach would be and have both weighted in terms of monetary losses or reputation (Jacobs 2012).

6.2 Bring your own device (BYOD)

6.2.1 Overview

This term is defined as the permit for employees to bring and use at the workplace personally owned devices such as laptops, smart phones or tablets (Wikipedia 2018).

One of the main reasons of BYOD is organisations reduce costs in hardware expenditure. In some cases, these devices receive the same kind of support like business owned device. On the other hand, this is not true in other situations where they are part of a system called shadow-IT where hardware is not supported by the IT department of the organisation. If there is no technical support within the organisation, usually employees receive some financial relief in order to purchase and maintain the device (Rouse 2011).

Regardless corporate support or not, organisations that allow BYOD usually have well defined policies to avoid and mitigate IT security risks. For instance, there might be some usage restrictions with regard of some application, it might be required to have the device encrypted. In addition, the organisation may require periodic audit of the device to make sure policy compliance (Beal 2018).

Challenges

There are a range of devices on the market with different operating systems. This means implementation of security measures is not an easy step to achieve since any device should be

supported. Continuous monitoring to protect new and existing devices and adjust security measures might become a burden for IT department responsible for maintenance. Figure 1 shows security challenges involved in BYOD:

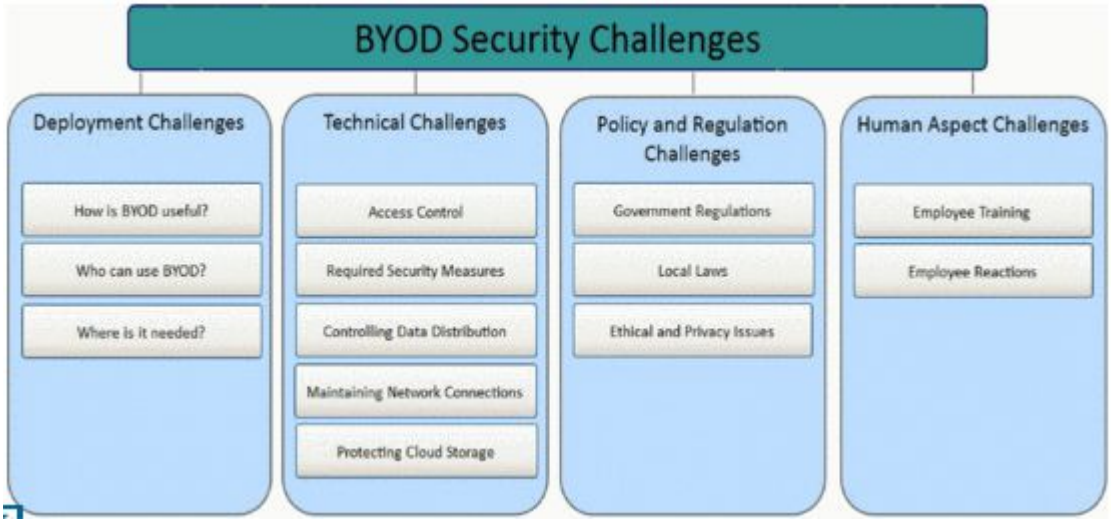


Figure 13 - BYOD security challenges. Source: https://bit.ly/2HUFOhN

Data protection is the main worry for organisations that allow BYOD. Data monitoring is possible provided it remains in the corporate network and become a challenge and out of company control once it leaves their network. In those cases where employees work from remote location and connect for instance to public wi-fi hotspots, there is a threat coming from possible unprotected public wireless points other than from unproperly secured home networks (Downer et al. 2015).

Loss or theft of devices also poses a high threat and could expose organisations data to outside people. According to Symantec's 2012 Honey Stick Project, it was found that for 70% of lost devices, organisational data and information were being accessed by those who had found those devices. Furthermore, there is an additional risk of corporate data leaking if an employee leaving the job does not erase device hard drive.

An additional challenge is represented by local legislations that may limit the control organisations have on employees owned devices. For instance, if due to an expansion the company decides to hire a distance worker in a different country, they will need to align any policy with local laws. This enhance further the burden for the company to rationalise employees contract and supervise laws changes (Sobers 2015).

Example of incidents

There were several cases where lost or stolen personal laptops containing corporate and customers data, have lead companies towards catastrophic situations. For instance, a doctor of the Massachusetts Eye and Ear Associates, Inc. got his personal laptop stolen containing sensitive patients' information pertaining to the company. The result was a $1.5 million fine for violation of the HIPAA (Health Insurance Portability and Accountability Act)

In a different though similar situation instance "Coca-Cola suffered from a data breach when an employee stole many laptops over the course of several years. The employee reportedly stole 55 laptops over a 6-year period. This breached over 18,000 personal records, and part of this data included social security numbers. There were also 56,000 records covering other types of sensitive data that were breached as well" (Hourani 2018).

The above are just two examples of scenarios that could lead the company to a multimillions EURO fines and compensation for data breaches under GDPR.

6.2.2 Best practises

Policies

Regardless corporate support or not, organisations that allow BYOD usually have well defined policies to avoid and mitigate IT security risks. For instance, there might be some usage restrictions with regard of some application or it might be required to have the device encrypted. In addition, the organisation should require periodic audit of the device to make sure policy compliance. This because there might be opportunities to use the device for unlawful activities (Beal 2018).

Training

Training and education for employees is a key point to make sure everyone in the organisation is aware of company policies and most importantly of the risk that BYOD involves. Since technologies and risks changes overtime, is paramount to have recurring trainings for instance every six months or at last once a year.

VPN

Among measures that can help to securely access corporate or other organizations networks, Virtual Private Network (VPN) plays an important role. With the use of appropriate applications, VPN allow to establish a secure and encrypted channel between the client (personal owned devices in this case) and the server avoiding situations like man in the middle. An overview of how VPN works is in the below image:

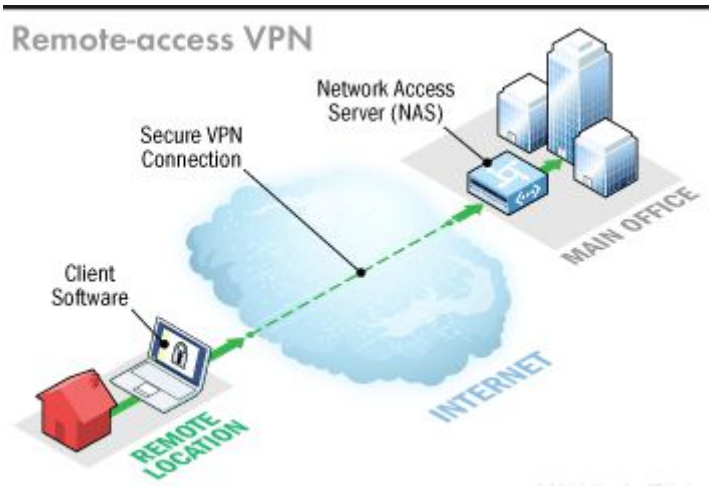


Figure 14 - VPN connection from remote location. Source: computer.howstuffworks.com/vpn3.htm

Mobile Device Management (MDM) and Mobile Application Management (MAM) are comprehensive frameworks that allow organisation much more granularity over device control. They consist of a main application that resides in the company network and an agent deployed in the device. Through the main application, the organisation monitors the device and verify the originality of the security certificate exchanged, impose access rights, encrypts communications and the device itself, update enforcement policies, can remotely scan the device for viruses and malware and ultimately wipe the device should this be lost or fall in wrong hands (Bartolozzi et al. 2015)

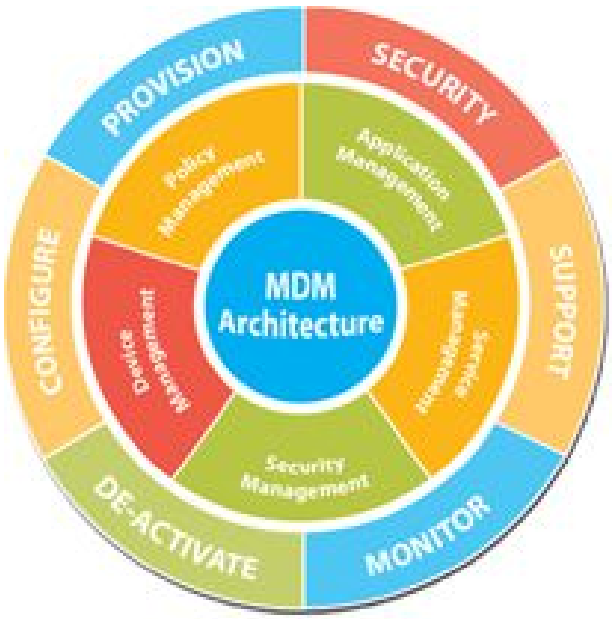


Figure 15 - Overview of MDM architecture. Source: https://bit.ly/2KC6YrC

Summarising, while on the one hand BYOD allow organisations to save money and to some extent provide a better employee experience, on the other hand companies need to implement proper policies and framework to keep control over devices. MDM is possibly the best and most comprehensive ways to do so, however cost analysis (in terms of hardware, MDM and fines for GDPR purposes) should be the starting point to evaluate advantages and drawback of the system.

6.3 Customer service

6.3.1 Overview

The company has an excellent customer service team, very responsive and customer obsessed. They get customer inbound requests through different channel such as email, phone and social medias. When communicating by email customers sometimes send attachments like screenshots taken of issues they are facing on the website or other text/pdf documents. Customer service advisors (CSA) arrive in the office in the morning, boot their laptops and start checking customers email opening attachments when any is included in customer emails.

CSAs have noted sometimes attachments do not open after clicked and there is no error text or any other popup windows on the screen. This has reported to the IT department that after checked on this have not noted any issues.

As mentioned, another channel customers get in touch is by phone. CSAs working at the call centre often receive off topic calls from people that accidentally type the wrong phone number or that call the company on purpose asking unrelated questions. Although off topic, CSAs at the company are very friendly and go the extra miles to help customers when possible.

6.3.2 Social engineering

Figure 16 - Source: iconiumnetworks.com

According to Wu et al. (2006b) "phishing is considered a semantics-based attack, which particularly exploits human vulnerabilities, but not system vulnerabilities". The aim of attackers is to decoy users to send them any confidential data often using "techniques such as appeal to vanity, appeal to authority and appeal to greed" for their attacks. Many social engineering exploits simply rely on people's willingness to be helpful" (Rouse 2014). A very common type of attack is by someone that disguise as technical support team and pressure the victim to hand in credentials to login the system highlighting a serious IT issue in the organisations that requires immediate attention.

An important aspect to consider is common people do not realise that divulging even a small piece of information such as name and date of birth help, hackers to have access to the system. Often perpetrators have already conducted a reconnaissance phase gathering victim information from different sources like social media or company website. Once inside and with knowledge of credentials it is easy to reset it, escalate privileges and gain unlimited access to the system (Kaspersky Lab 2018).

Social engineering attacks come under different forms such:

Pretexting: the attacker claims to be for instance someone from IT or financial departments that need to verify victim identity.

Spear phishing: this is accomplished by sending an email pretending to be a friend or known institution with the aim of having the victim to click on any attachment or forged links. The

consequence is a malware that is installed in the victim machine first and spreading through organisation network later.

Baiting: in this case the attacker leaves a device such as USB drive close to the victim facilities. Unsuspected employees find the drive and curios of what is in it, plug it in triggering automated malware installation.

Scareware: the attacker simulates a message for the victim his machine is infected by a virus or has downloaded prohibited material. The attacker then offer help, but the outcome is the victim download and install a malware.

For the purpose of this project the most common social engineering attack is investigated: spear phishing.

6.3.3 Phishing analysis

According to Rouse (2017), "Phishing is a form of fraud in which an attacker masquerades as a reputable entity or person in email or other communication channels. The attacker uses phishing emails to distribute malicious links or attachments that can perform a variety of functions, including the extraction of login credentials or account information from victims".

The goal of the perpetrator is to have the receiver click on any link or attached documents/images. Usually the outcome is a silent installation of a malware without the user noticing anything irregular at that time. Once installed the malware may start seeking for particular sensitive information, establish a hidden network connection with the attacker machine and steal any data. Sometimes the malware present itself hidden under a what seems known and trustworthy website link like Google and requesting the user to click and login to verify credentials. Unaware of what is behind it, the users click and enter credentials without knowing the website was a clone and his credentials are now knowledge of the attacker.

Challenges

Obviously, the main challenge of the person that receive a phishing attempt is be able to identify some clues that should sound an alarm. An example of forged website and the original one is shown below:

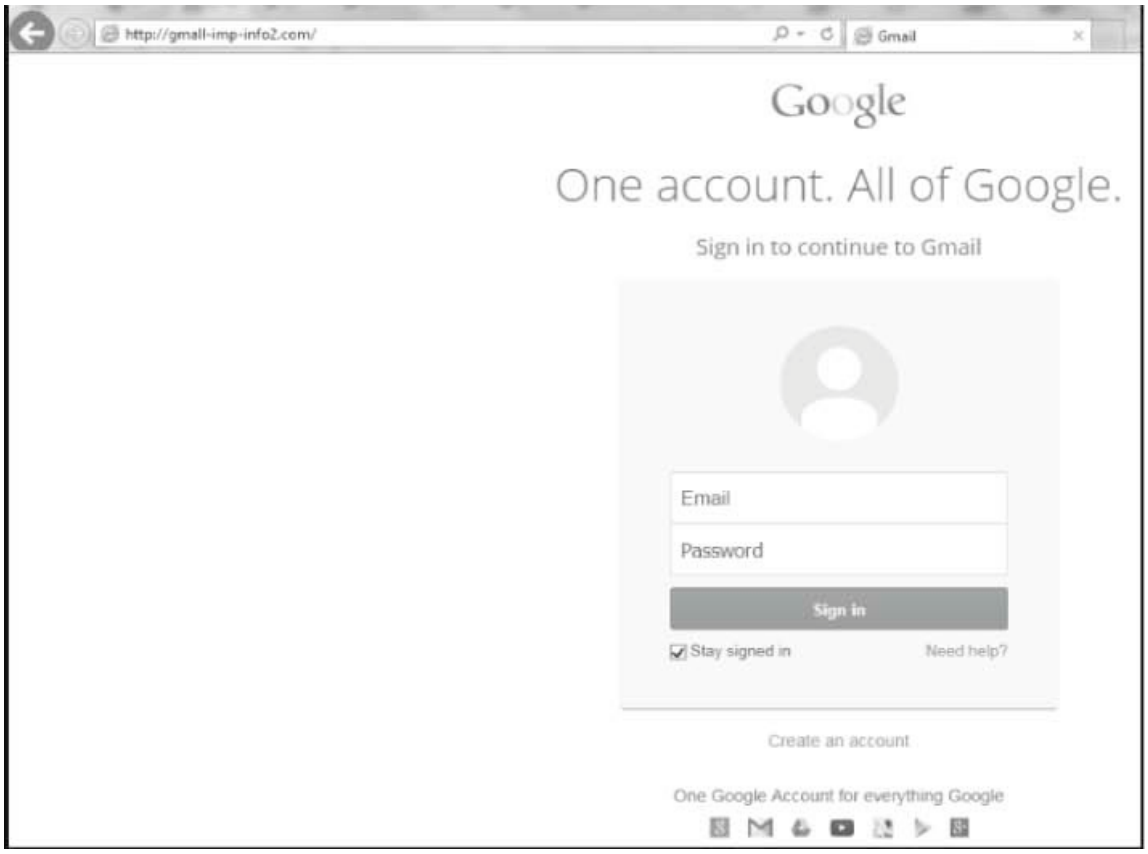


Figure 17 - forged website. Source Aleroud, A, & Zhou, L 2017

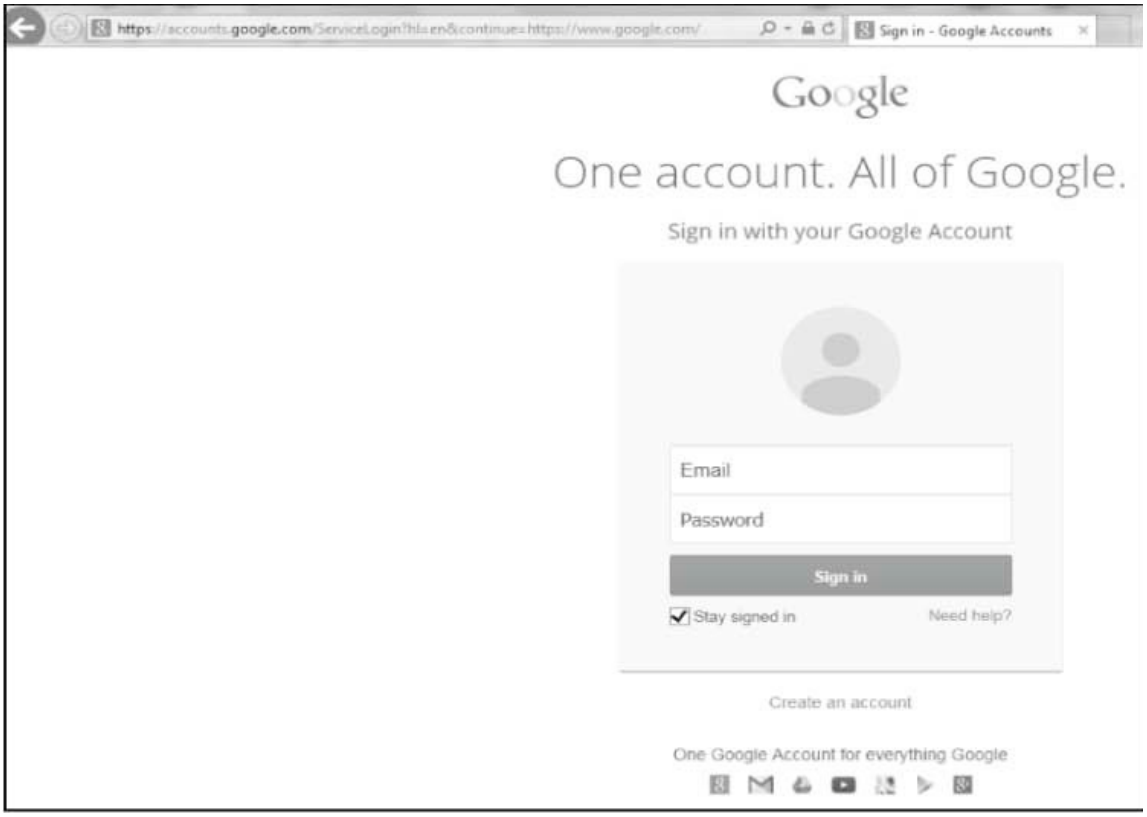


Figure 18 - Original website. Source Aleroud, A, & Zhou, L 2017

At the first sight both websites seem the same but there are some substantial differences:

1. In figure 1 the URL http://gmail-imp-info2.com is missing the "S" at the end of the HTTP. Why this matter? HTTPS is the secure transfer protocol meaning every time it is at the beginning of the URL, communications between our browser and the server are encrypted by an SSL.
2. Figure 1 has missing padlock at the end of the URL bar. This means the website is not secure
3. Looking closely at the URL of figure 1 it is clear it is a fake domain and not a genuine Gmail domain (http://gmail-imp-info2.com against https://accounts.google.com) (Aleroud et al. 2017).

Phishing emails usually are difficult but not impossible to distinguish from genuine ones. They often have what seems original company logo or email address, come from someone known that in our case could be a customer and contains information specific to our person, colleague or business. Figure 1 and 2 show a sample phishing email:

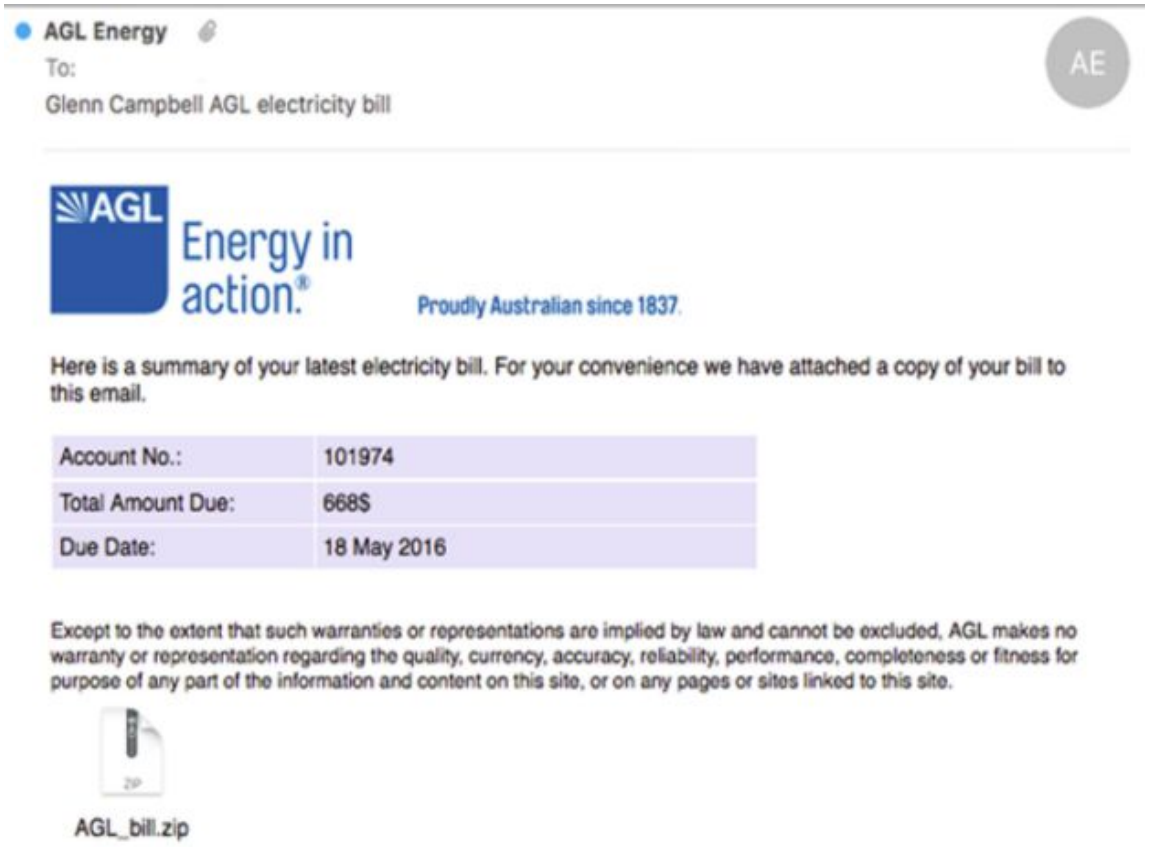


Figure 19 - Phishing email. Source https://bit.ly/2JQ9ppd

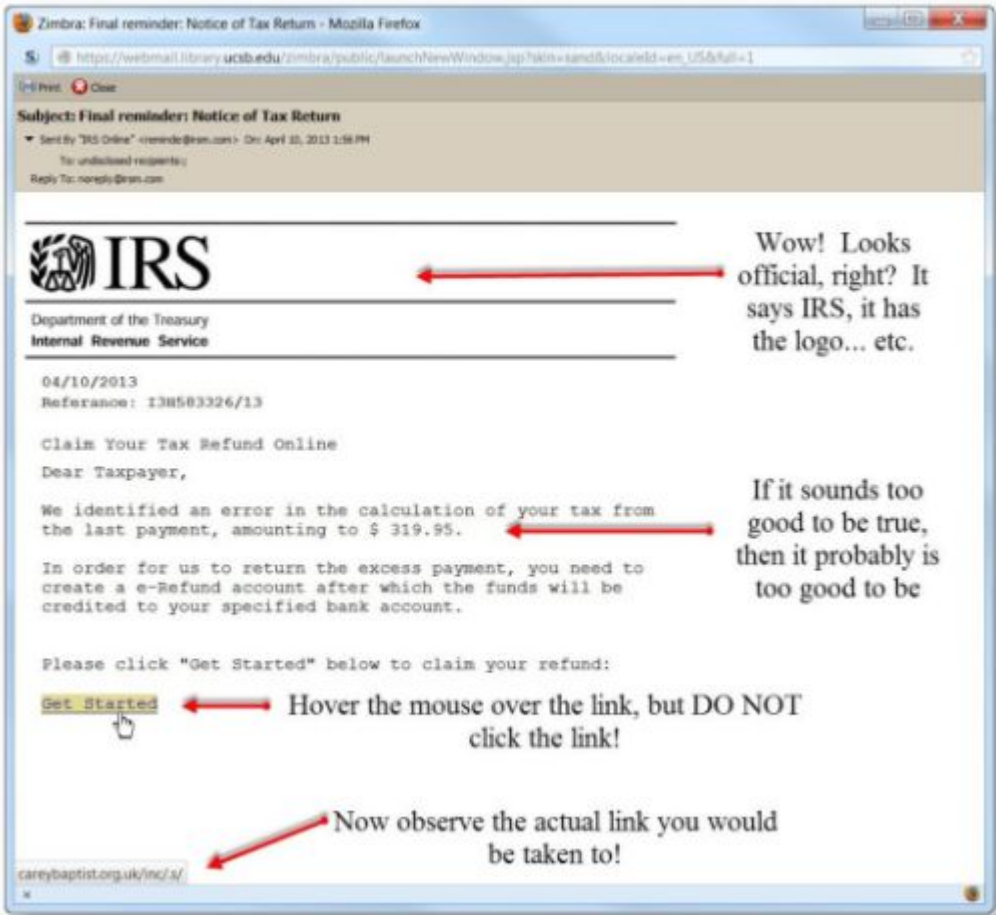


Figure 20 – Source: https://bit.ly/2uCHPJn

How to recognise a phishing email.

There are some easy steps to follow to identify if the email received is from a trusted source or not:

1. Was that email expected and is the sender in our list?
2. Does the email contain threats such as this one?

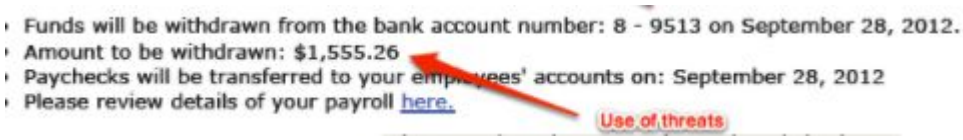


Figure 21 - Source: https://bit.ly/2roazRj

3. Is required our urgent attention?

4. Are there no names or other contact details in the footer?

5. Are there any clear spelling errors?

Our records indicatethat you never did not answer to requests for additional information

This is an example of a classic phone call from social-enginnering.org website https://www.social-engineer.org/framework/general-discussion/common-attacks/phone/ that put the target under pressure to give away financial information:

"The facilitator of a live Computer Security Institute demonstration, neatly illustrated the vulnerability of help desks when he "dialled up a phone company, got transferred around, and reached the help desk. 'Who's the supervisor on duty tonight?' 'Oh, it's Betty.' 'Let me talk to Betty.' [He's transferred.] 'Hi Betty, having a bad day?' 'No, why?…Your systems are down.' She said, 'my systems aren't down, we're running fine.' He said, 'you better sign off.' She signed off. He said, 'now sign on again.' She signed on again. He said, 'we didn't even show a blip, we show no change.' He said, 'sign off again.' She did. 'Betty, I'm going to have to sign on as you here to figure out what's happening with your ID. Let me have your user ID and password.' So this senior supervisor at the Help Desk tells him her user ID and password." Brilliant".

Example of incidents.

In 2010 a malware called Stuxnet, hit Iran in what seems a real first cyberwar attack. This malware attacked and compromised what is estimated to be the 30% of Iranian's enrichment centrifuges plant collecting information on industrial systems and causing the fast-spinning centrifuges to tear themselves apart. It is said the attack vector was likely a USB stick left outside the plant facility and recovered by an employee that inadvertently plugged in a PC and triggered the malware installation (Holloway 2015).

An American IT company called Ubiquity Networks Inc., was victim of a $46.7 million phishing fraud in June 2015. Through was seemed a genuine request, the attacker impersonated an employee and lead the financial department to a bank transfer in overseas accounts. Ubiquity employees thought they were receiving genuine applications from stakeholders at the light of spoofed email address and look-alike domains (Brecht 2016).

Another singular attack was performed against cyber security company RSA (subsidiary of EMC). Attackers targeted a number of employees with a properly crafted email with subject "2011 Recruitment Plan" and containing an attachment called "2011 Recruitment plan.xls". Once employees opened the attachment a backdoor installed and gathered credentials and other sensitive information that was then sent remotely to the perpetrator.

All the above cases and the RSA one in particular, have shown how any company even the ones at the forefront of cyber security can be easily victims of social engineering attacks.

6.3.4 Best practises

Social engineering is a psychological attack against the individual and not a system exploitation. The key point is awareness of the company customer service and employees in its whole. Involving personnel in recurring trainings for instance annually, is crucial for the company to stay up to date and refresh their mind against the danger behind this technique.

Training should include an explanation of different scenarios like the ones mentioned above, and the company should also have a system in place to randomly send a false phishing email and perform fake phone calls to audit employee awareness. This latter technique is an industry standard nowadays among Small-Medium-Enterprises (SME).

Train employee to never divulge username, password, internal phone numbers and other company information by phone or email. Ask basic questions such as name, phone number and email to those people that contact by phone and start questioning customer service advisors.

Use of technologies such as antivirus and spam filters can help to identify malicious attachments and suspicious links when emails are received in the mail server. Blocking those emails before they arrive to the individual can reduce the likelihood of infection.

Table 1 is a summary that the company could use and hand to employees as a reminder on how to identify a potential phishing email.

Table 1: handy phishing reference table

Clue	Yes
There are grammatical errors in the email text/footer.	**Proceed with caution.**
The email contains attachments or links which invites to click.	**Avoid clicking on the attachment and links. Hover over the link with a mouse and see at the bottom of the window the real web address.**
The communication request some personal information like name, DOB, ID, password etc.	**Genuine organisations do not ask personal information like this by email, so do not reply.**
The sender email address is known.	**Although the sender could be known, it is still advisable to proceed with caution. Someone may have taken control or**

	infected their email and sending out malicious code.
The known sender does not refer to the addresses by their name.	**Proceed with caution.**

Ultimately visit https://www.social-engineer.org a dedicate site to the social engineering threat. There are very useful resources including monthly podcast where security experts discuss how information security is affected by human behaviour.

6.4 Corporate network

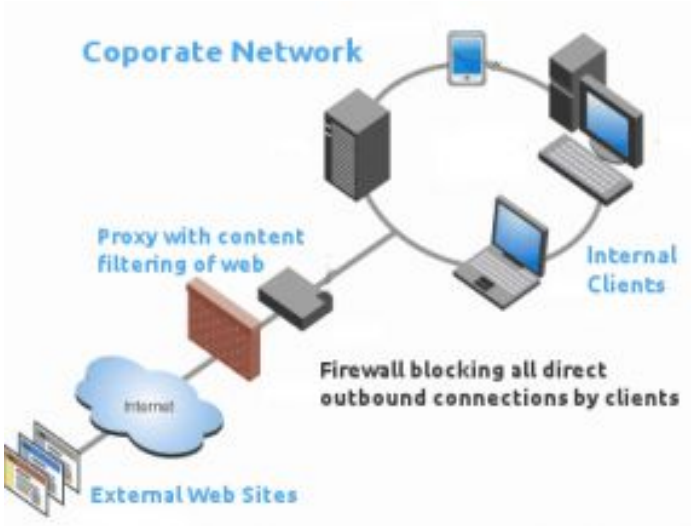


Figure 22 - Source: hackertarget.com

6.4.1 Overview

The term Corporate Network, often referred as Corporate Area Network (CAN), is a company internal network segregated and isolated from the public internet. Users navigating CAN do not have connection to the public internet (rouse 2018).

CAN is a network that connect internal IT infrastructure of a company such as computers, network printers and other devices. In addition, CAN put in communication different departments each one with access to the relevant resources. CAN users for instance can access internal company material such as policies, training files, submit request to their HR departments, escalate customer queries and issues internally, check their employee's status, contract etc.

To be able to access their dedicated resources, IT admins need to set proper authorisations for each user when they enrol into the system. This is done firstly by authenticating the user (Are you who

you claim to be?) and secondly by authorising the user to access determined resource. For instance, employees working in the HR department at the company need to be able to access the HR administration section of the CAN and not the resources dedicated to the billing department. Likewise, billing departments employees should not have access to the HR administration resources and so on. Basically, each user need to be authorised to access and perform actions only for the resources they are allowed to do so.

Usually in SME, AC is achieved by creating groups for roles and assigning specific permission to that group so that each person enrolled in that group has access to a set of predefined resources (Role Based Access Control) (Martin 2016). For instance, there is a group called "hr_team" to which are associated 5 different tools. If an employee is enrolled in that group, they will have access to those 5 tools by using proper login details. On the other hand, if the organisation embraces Single Sign On (SSO) this helps to avoid the hassle of assigning a password for each tool. Instead, users' login with one password and are granted access to all tools (Infosec Institute 2018).

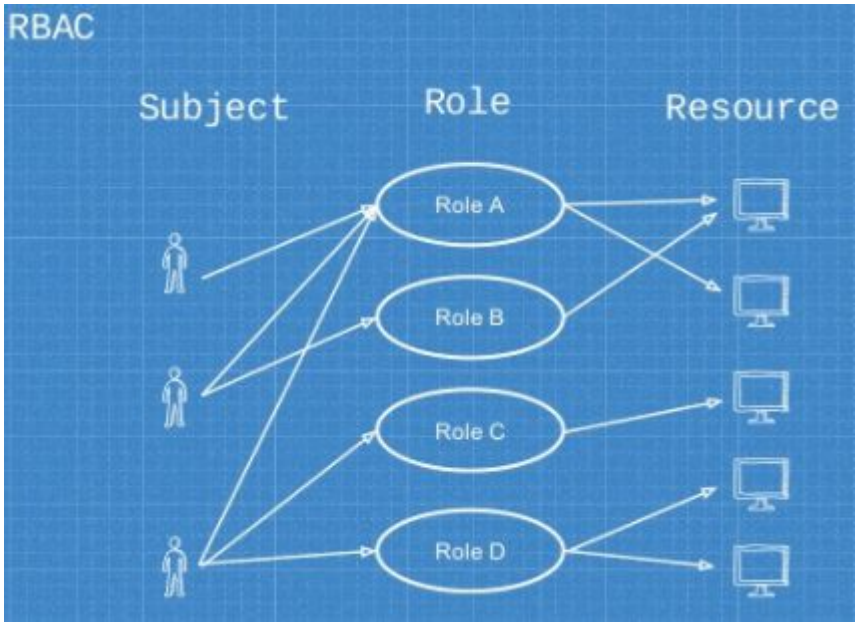


Figure 23 - Source: idenhaus.com

Challenges

Although lot of attention today is paid to authentication to make sure only authorised people have access to the system, for the majority of enterprises the biggest challenge is authorisation. In particular, create, update and maintain policies overtime to make sure to have under control who access what, can become difficult and go out of control also due to the dynamic evolvement of IT infrastructure, applications and workforce (Martin 2018).

An additional challenge is represented by revocation of permissions for instance when an employee laves the company or change department. In this case IT department should revoke

permission as soon as possible to avoid unintended access but this is not always the case. Manually going through employee account, check permissions they have and disable access is for some organisation cumbersome and resource intensive not to mention human errors.

It is commonplace organisations today to use several tools, mostly cloud applications, that of course requires authentication. Thus, remembering a number of password is another challenge organisation's employees faces with consequent poor user experience (Velazquez 2016).

Example of incidents

In 2014 AT&T reported an employee had access to some customer's information such as social security numbers and driving license. The company communicated with affected customer and stated one of them employees had violated privacy rules (Kerner 2014). Impact for AT&T is not only in terms of money but also from a reputation prospective.

6.4.2 Best practises

Use the principle of least privilege to give a minimum level of permissions to carry basic tasks.

Proper password policies in place can help prevent or at last limit unauthorised resources access. For instance, have mandatory password change every 90 days for employees and anyone in the organisation. If a password is stolen the damage can be limited and avoid the attacker return after a period of time.

Use of Multi-Factor Authentication (MFA) allow to have a second level of security in case of password beaches. A tool like Google Authenticator provide a randomly generated number the user will need in addition to the password. Access to the system is granted only if both password and MFA code match.

Have a unified Authorisation Solution in place to control under the same panel, privileges, and rights management. In a single unified system such as EB2BCOM "With all access policies in one place, organisations will have a solution that is easier to audit and maintain, which will increase the overall security and accuracy of policies" (EB2BCOM 2018).

6.5 Cloud server and the Internet

Figure 24 - Source: 123rf.com

6.5.1 Overview

A server is a device with special software (think of it like a computer) that offer a service to another computer through the internet. In its most common form, a web server allows to navigate the internet providing access to web pages. The connection is initiated by typing a web address (URL) in our browser (client) that subsequently will connect to the web server around the world where the website is hosted. This content retrieve is possible through two main protocols that are the foundation of the Internet: Transmission Control Protocol (TCP) and Internet Protocol (IP).

When a user types the web address in the browser, TCP protocol initiate and establish a connection between the client and the server and split data into packets. At this stage the IP protocol initiate exchange of information routing those packets to the right destination. In our case this means the user starts to see pages and any other content requested (pictures, videos, etc) of the website they are connected to, downloading in the browser.

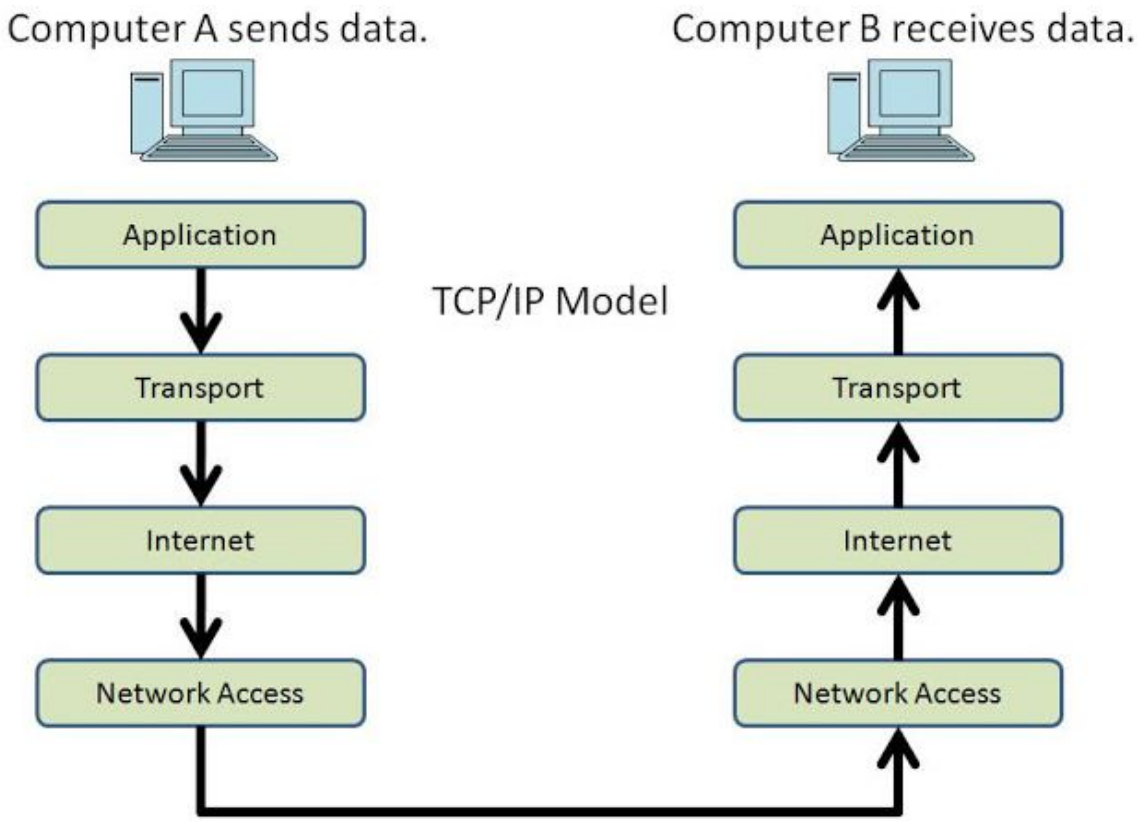


Figure 25 - Source https://bit.ly/2FL4fbK

Back in the time, organisations used to have their own servers on premises. This required a dedicated team of employees to give maintenance and troubleshoot any issue in case of any failure plus excessive cost for parts and device replacements when obsolete. With the advent of the "Cloud" there was and there is a shift still in place where workloads are being migrated to cloud servers leased by Cloud Service Providers (CSP). The advantage of the cloud can be summarised in few points:

- Cloud servers are usually rented on monthly/hourly basis becoming a monthly expense (OPEX) rather than go though company budget every year (CAPEX)
- Once the server is deployed in the cloud, organisations can deploy/reclaim additional resources in matter of minutes allowing a great degree of flexibility (for instance the company has a duplicated number of visitors on their website before Christmas and need their server to be able to accommodate more request from clients).
- Maintenance and troubleshooting is usually done by CSP technical support that often is included with the leasing. Organizations can therefore free up resources and dedicate employee to other departments of the business.

The company host its website on a cloud server. Customers navigate the site, make shopping and contact customer service using their browser.

Challenges

The company website has a section where new customers can open an account entering personal details like name, address, phone number and enter credit card number. In addition, recurring customers need to login to access their account before making any purchase. All the above is sensitive information and none, other than the user, should be able to read/access it. This is not always the case because perpetrators are always in search of potential victims for instance to steal personal details and take advantage of it.

Man in the middle (MIM) is one of the most common scenarios where an attacker, using proper tools, position himself between client and server capturing information that are exchanged.

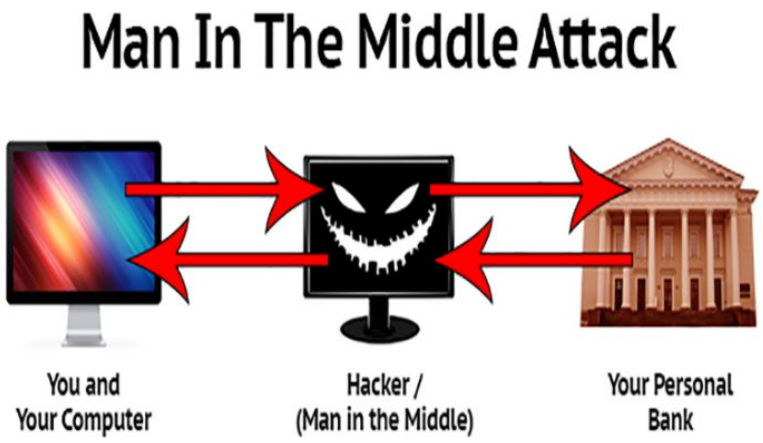


Figure 26 - Source: osradar.com

Web forms, used to gather customer information, and login pages could also be a source of vulnerabilities allowing a malicious guy to infiltrate the cloud server and download users' data. In addition, this could also lead an attacker to become the controller (root user) of the cloud server therefore be able to shut down the website and delete all data in it. But how a web form can be so dangerous?

The company website store customer data and login details in an SQL database. Each time a new customer opens an account or an existing customer enter login details in the relevant fields, the application communicates in background with the database to save and retrieve information. Upon this exchange of data, the customer is logged in their account or a new account is created.

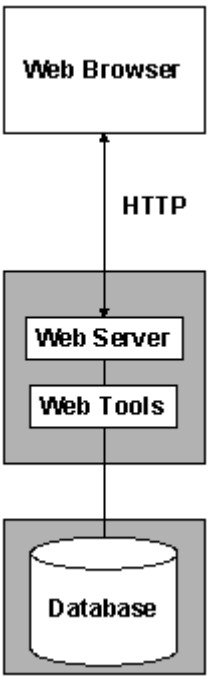


Figure 27 - Source: help.sap.com

Data is transmitted using programming language that has its own structure. With a good knowledge of the SQL language syntax, an attacker can inject some malicious code through web forms and login as a user. Ultimately, get customer data back in the browser.

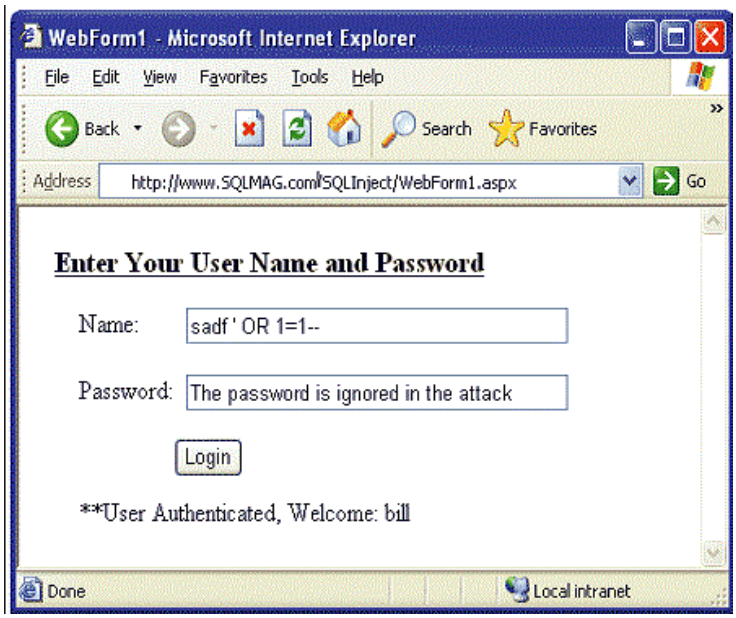


Figure 28 - Source: tut-house.blogspot.ie

Weak customer passwords

An additional challenge that could pose customer data at risk is the use of a weak password. In today digital world an individual may have tens of online accounts for different purposes and each of them requires a password. It is therefore commonplace use words or a sequence of numbers easy to remember as pin/passwords and often use the same email-password combination for different accounts.

Figure 29 - Source: www.peopleforresearch.co.uk

The same way those passwords are easy to remember, attackers use common passwords lists to try, one after the other, brute forcing login pages and eventually gain access to the system.

Other than customers and genuine visitors, the company website attracts also perpetrators with the intent to exploit the system and steal precious private information. Some of the attacks are also against the infrastructure (cloud server machine) that has different listening channels (ports) by which interact and exchange information with the public internet or internally (database). Again, with the use of proper tools, perpetrators can find and probe server ports and possibly exploit vulnerability that can lead to take over the system.

Examples of incidents

In September 2017, a hacker was able to exploit a vulnerability in Apache web server that was used from Equifax (credit agency). The outcome was records of 143 million personal information of Americans stolen (Collins 2017).

6.5.2 Best practises

Investing in secure programming should be the first step to make sure our web application can defend against code vulnerabilities. Today programming agencies are mainly focused in going to the market as fast as possible to make money and beat competitors. Thus, once the application has tested and all functionalities are working, the product is ready to be sold. It seems there is not so much focus to make sure security testing are conducted along the way and among different development stages. This also because secure programming costs money and slow down the

development phases. However, if any organisation develops its own software, it is crucial to test it for security and not only for functionalities. To make sure applications have a certain degree of security, organisations can also avail of third party services to conduct web app testing and penetration testing. A report is usually delivered highlighting vulnerabilities found and advising for fix. This will allow to some extent avoid data breaches that under GDPR will cost lot of money especially if investigations find out there were no precautions used.

The above has shown how a MIM could eavesdrop communications and capture data between a customer and the company website. By the use of encryption communications through the internet are secure and plain data is not captured/modified by third parties satisfying confidentiality and integrity part of the CIA triad. An industry standard method to encrypt client-server communications is Secure Socket Layer (SSL) and Transport Layer Security (TLS). When communications are encrypted the system shows in our browser a lock and the URL with an "s" at the end.

Figure 30 - Example of a secure communication. Source: https://bit.ly/2jvzcYD

The company can take advantage of additional benefits of SSL certificates other than encrypt communications such as (Acmetek 2018):

- Build customers trust and increase sales
- Displays a security seal on their site
- Safer experience for their customers
- They can protect customers and internal data

Weak passwords play an important role in data breaches. The company web application should implement some rules for customers opening an account for instance not permitting password less than a certain amount of characters and that must contain capital letter and numbers. According to Microsoft (2018), a password must be at least 8 characters (14 for greater security) and contains one at least three characters of the following groups: lowercase letters, uppercase letters, numbers, and symbols (Microsoft 2018). In addition, MFA can make the system even more secure (see 6.4.2)

Use of Firewall is another industry standard to help block malicious traffic. There are two main types of Firewalls: software or hardware based. A software Firewall is essentially a software application that runs on the device it protects (for instance Windows Firewall that comes with the operating system). Thus, each device needs its own software to be protected. On the other hand, a hardware Firewall is a physical device usually deployed in front of an IT infrastructure to filter incoming traffic. It can therefore protect any device behind it.

While a software Firewall filter and block traffic when this has already reached the device (with potentially crashing the device if the Firewall itself crashes), a hardware firewall block malicious traffic before it reaches the device at all (TechAdvisory.org 2017). Additionally, help to meet industry standards such as Payment Card Industry (PCI) that applies to organisations like the company that accept credit card payment. In fact, data processing involved in credit card transactions need to be securely hosted (Online Tech 2018).

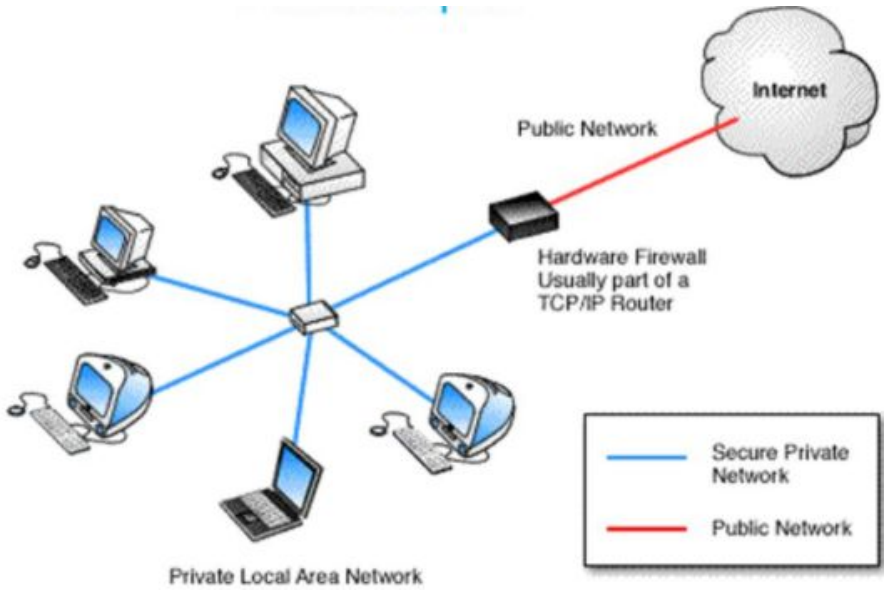
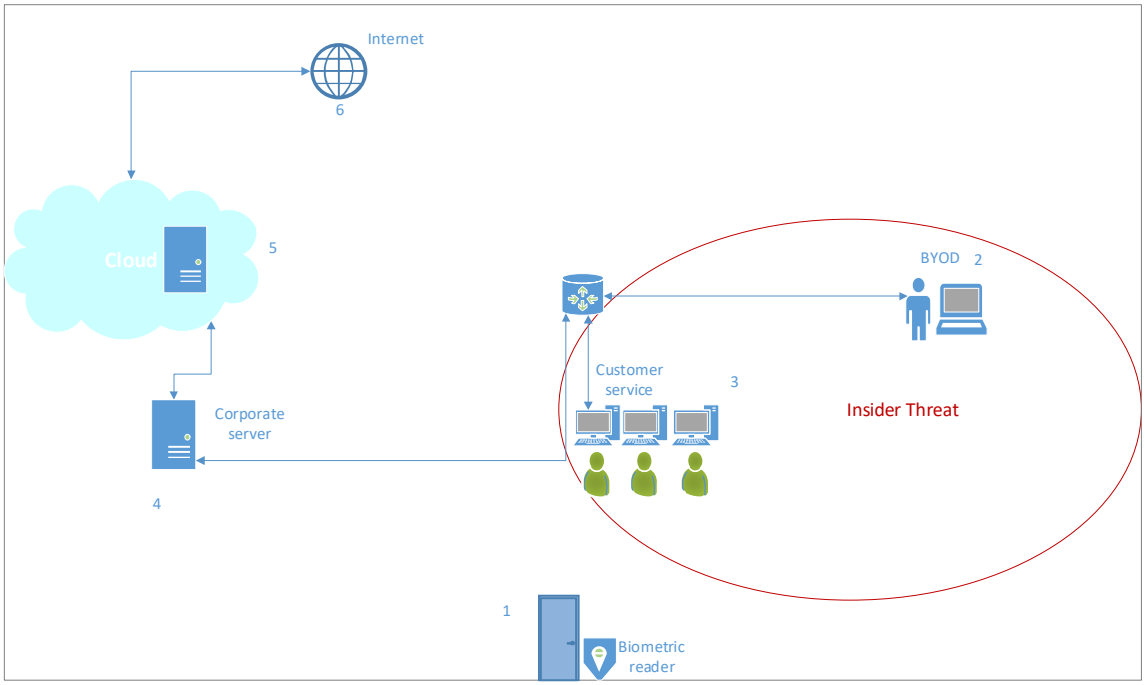


Figure 31 - Example of a hardware Firewall. Source: http://slideplayer.com/slide/10745843/

Use of resources is also to keep in mind when deciding the right Firewall for our organisation. For instance, if the company has a cloud server that has not spare resources other than the right ones to handle client requests, a hardware Firewall could be the right solution since it runs off the server freeing up resources to the server itself.

6.6 Insider threat



6.6.1 Overview

Insider threat is someone internal to our organisation that can pose our infrastructure at risk not only in terms of security but also reputation. While someone may think the internal attack is intentional, this is not always the case. According to a 2016 cyber security report from IBM (2016), it was found that 60% of cyber-attacks were launched by insiders and of those about three quarters were intentional while one quarter was inadvertent (Zadelhoff 2016).

Insider attackers may have different reasons to cause damage to their organisation. It could be the insider is not happy about something in their position and decide to find revenge for instance stealing confidential documentation and publish it online or sell to competitors. Or an employee may be engaged from someone externally and offered a quantity of money to provide some internal information or credentials to access the organisations system (Tripwire 2017).

Challenges

Figure 32 - Source: insights.sei.cmu.edu

What about those "unintentional" insiders? How can an insider be "unintentional"? Back to what was already mentioned in section 6.2 about dangers coming from BYOD, it immediately answers this question. Loss of devices, stolen credentials, phishing attacks, emails with sensitive attachments inadvertently sent to the wrong addresses are just an example of how an insider attack could be inadvertently placed and cost a fortune to the company do not mention the cost of reputation and loss of business.

Insider threats are a difficult to defeat for different reasons. A silent insider may go undetected for long time, often years because they tend to work silently in background without causing alarms. If an employee works with sensitive data as part of their department duties, it is challenging to understand if that information is being stolen and leaked even more if the employee knows how to cover themselves do not leave any trace.

An additional challenge is presented when the organisation detects the offence and has to prove it. Depending on the case, the employee may claim they were not aware of it and was just a mistake (Tripwire 2017).

Example of incidents

In 2015, Ukrainian power companies suffered a cyber-attack by which an outsider was able to gain access to the system by a phishing attack that targeted some employees (unintentional insider). The outcome was an outage that affected about 80000 customers.

Everyone remembers the most wanted man in the world Edward Snowden (CIA former employee) that in 2013 leaked secret details of US domestic surveillance conducted by NSA. It is said about

1.7 million documents were downloaded. Why Snowden did that? In his video declaration he says "I use to work for the government and now work for people. I gave that information back to people" (Snowden 2013).

An electrical engineer was fired and as revenge he deleted all data on company devices the business gave him in custody. The company suffered serious business damages since were unable to recover important business material (Thudium 2017).

6.6.2 Best practises

A first basic step organisation should take is do a background search on employees when they hire them. Although this is not bullet proof, can help refine and filter risky candidates.

Take care and understand why an employee may be unhappy is also an important factor to avoid unwanted behaviours. In addition, watch out for changing in habits such as an improvise change is life style of working hours that could a prediction of something happening in background.

Use user action monitoring software. This records user sessions that can later be analysed to understand what employees have done with data and can be ultimately used as proof in court if needed.

Education for employees. This section has shown how unwanted behaviours and mistakes can cause serious damage to the organisation. Recurring trainings with case studies and simulations, can educate employees about risks, security practises and consequence of their negligence. The aim is to make employees become part of the organisation security force and not a threat (Tripwire 2017).

As per section 6.4.2 use the principle of least privilege to give a minimum level of permissions to carry basic tasks and use strong passwords possibly with multi factor authentication.

Figure 33 - Source: observeit.com

6.7 Data encryption

The new legislation emphasises the importance of data encryption as additional measure for an "adequate level of protection ". Communications could be made more secure while in transit but how to add an additional layer of security while data is at rest?

Encryption can be achieved with different means. Firstly, using software to encrypt for instance specific files/folders or whole drives with sensitive data. Some examples of applications are FileVault2 and VeraCrypt (Rijnetu 2018). Secondly using Self Encrypt Drive (SED) technology. It relies on a hardware-based encryption system that encrypt all files on the fly when added to the drive. Authentication of the drive is done a boot time via either software pre-boot authentication or BIOS password (Wikipedia 2017). Most manufacturers today offer SED drives.

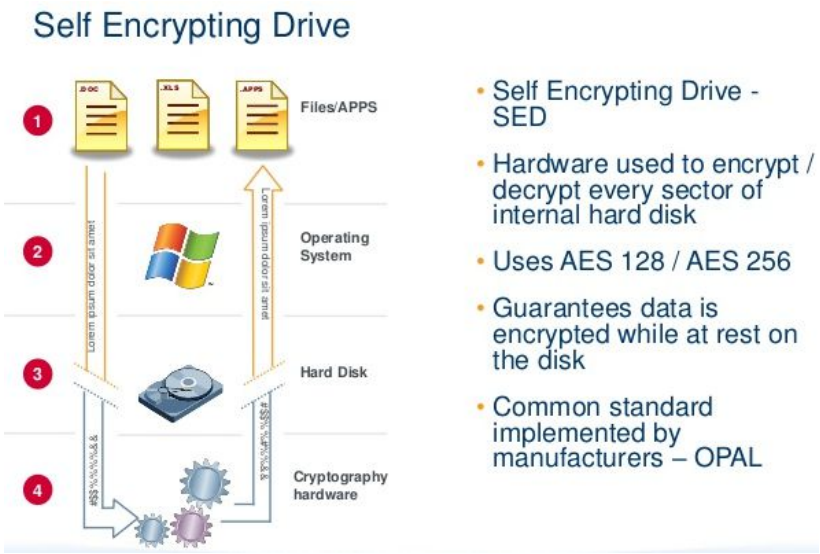


Figure 34 - Source https://bit.ly/2If5h4Z

Backups should also be encrypted either at rest and in transit. For PC-laptops this can be achieved using a SED drive or any other software based encrypted drive. For cloud servers and depending on the platforms, there are different solutions. One of them is Evault that make sure data is encrypted at any stage during the backup process (Brunelli 2017).

Chapter 7: Comparison with banking site

This chapter considers an online banking website with physical branches in different geographical areas and compare it with the company website. The scope is to give a general overview of an online medium-large organisation structure with higher security priorities and analyse some different requirements. For this use case, it is assumed all technologies, challenges and best practises of the company are already applied.

7.1 Online banking U-bank.com

7.1.1 Overview

This is a fictitious organisation (any reference to real businesses with same name is just a case) in the financial industry. U-bank is based in the UK with physical branches in EU and overseas. In addition, they have implemented an online banking service that allow their customers to comfortably carry out financial transaction on the move from both Pcs and mobile devices. Like the company, U-bank has physical premises (branches) where employees arrive in the morning, clock in and start working in their relevant departments. Each branch receives customers and has a customer service desk for inquires. All branches are connected together and there is a main office where the administration monitor the overall system.

The online website is composed of several cloud servers dispersed in 3 continents. All public facing servers communicate with back end (not exposes to the public internet) databases where customers and transaction data is stored. Figure 5 could represent the U-bank organisation.

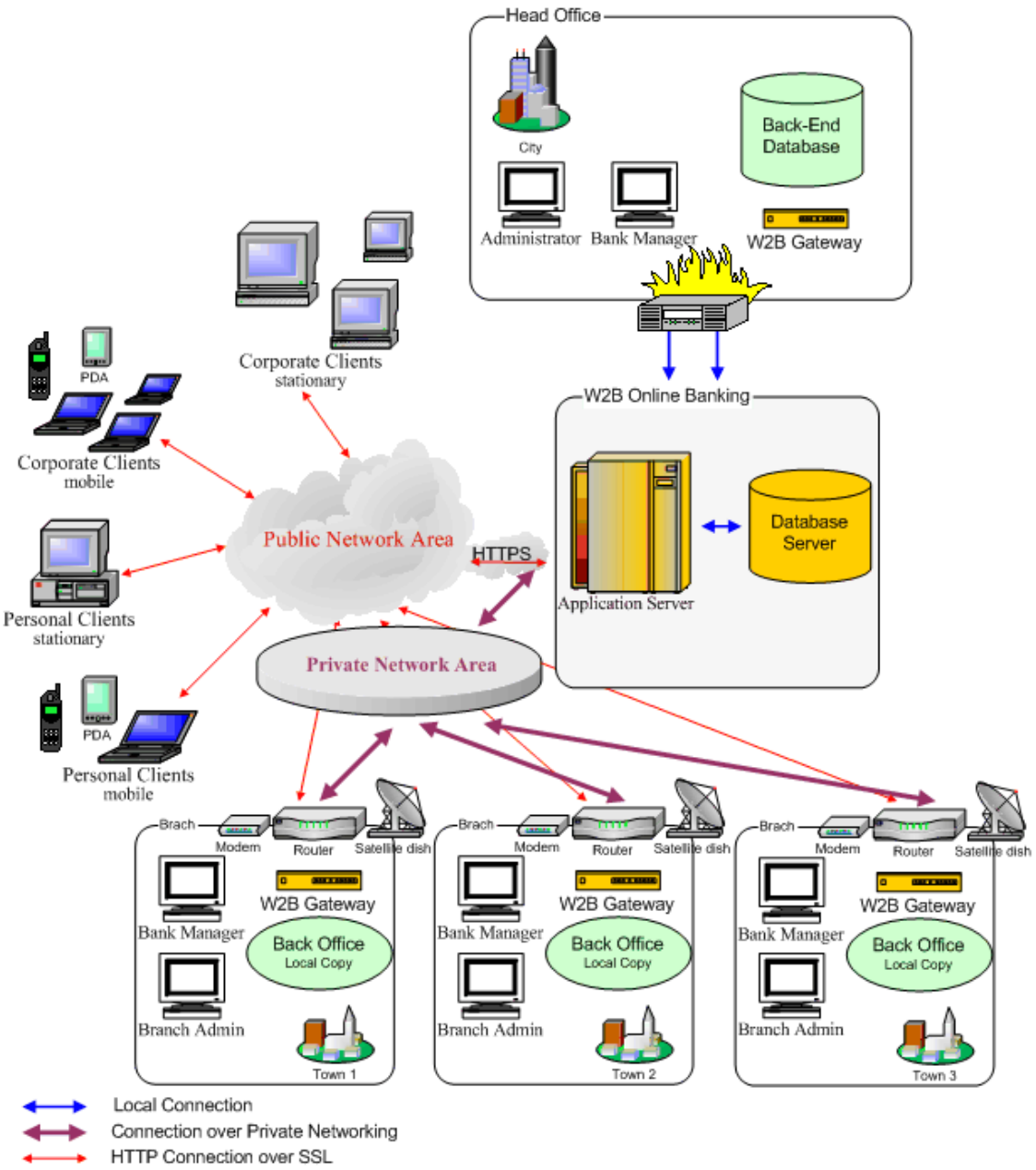


Figure 35. U-bank overview. Source: https://bit.ly/2JWKfp9

7.1.2 Comparison

Undoubtedly, due to the nature of the business and data involved, security has the highest priorities in a financial institution where bank accounts are stored and financial transactions take place.

While the company had their business in one physical location,. being U-bank a multi premises organisation where all branches need to communicate each other, it is easy to immediately spot the first big difference. The need to have a private secure network is a basic mandatory requirement to make sure all data is transmitted securely. Some CSP such as IBM, own submarine cables that connect all their datacentres around the world through an extended private network isolated from the public internet. International organisations such as U-banking, can take advantage of this

technology and have their servers securely communicate each other via the back-end network (IBM 2018).

In addition, "Customers moving sensitive financial, health or government-regulated data to and from the IBM Cloud platform helps ensure its security with IBM Cloud Direct Link". This technology consists of completely private own connection that organisations can establish directly to the IBM Cloud back end without passing for the public internet at all (IBM 2018).

Customers security logoff. Online financial institutions should pay particular attention to make sure customers are logged out the applications after a period of time of inactivity. The aim is to avoid any unauthorised activity/access for instance from an unattended/lost/stolen device.

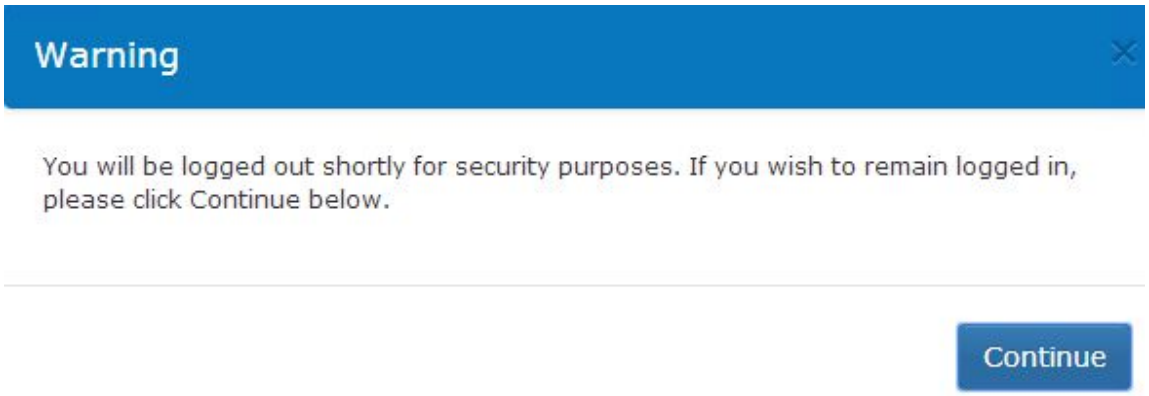


Figure 36 - Source: https://bit.ly/2Imfexo

Device registration: Some high-profile e-commerce ad financial institution already practice this good habit. It consists in fingerprinting the device/browser usually used by the customer to login their accounts. If a new device/browser is used, the system initiates an additional authentication system usually by sending a PIN by SMS or e-mail the customer will need to enter in the site before gaining access. This is an enhanced two factors authentication still to prevent unauthorised users access for instance due to stolen credentials (Kinderhood Bank 2018).

Customer protection: paper statements versus e-statements. Some financial institutions still post end of year statements or other documentation. Although this can be convenient, the drawback is expose banking information to anyone if the letter is stolen or lost. Anyone could have found themselves in this situation more than once when moving to a new house and forgot to change address. Financial institutions should not automatically post documentation especially for those customers that explicitly applied for online banking. This option should be limited to legacy accounts or those people that somehow do not have online facilities.

Account number not visible in the URL: As additional step for data protection, all financial institutions should implement this best practise masquerading the customer original account in the URL address with a random one or not showing it at all:

https://www.[redacted]bank.com/personal/xw-tyu2-ytop

Summarising, this section has shown how different level of protections need to be implemented depending on the application. Although this is true at the organisations end, it should not be forgotten the primary vulnerability is the user that is defrauded by different sabotages such as social engineering and phishing. Institutions should invest even more in campaigns to make users aware of the risks and vulnerability they involuntarily are target of.

Chapter 8: Python application for data mapping

8.1 Overview

This section documents the development of GdprSafe v1.0, a python application for data mapping. Data mapping is the first step organisations need to take along the journey to be GDPR compliant. It consists in understanding what kind of data they have, where it is located and who can access it and why. The outcome is a simple yet functional multi OS command line application (it can run under any OS like Win, MAC iOS or Linux both desktop or server version provided the user has the required library installed and python running properly) that deliver a report in the form of a cvs file with the document directory in one column and relevant key word found (if any) on the next columns.

8.2 System analysis and design

The application development follows the Software/System Development Lifecycle (SDLC). "Systems Development Life Cycle is a systematic approach which explicitly breaks down the work into phases that are required to implement either new or modified Information System" (TutorialsPoint 2015).

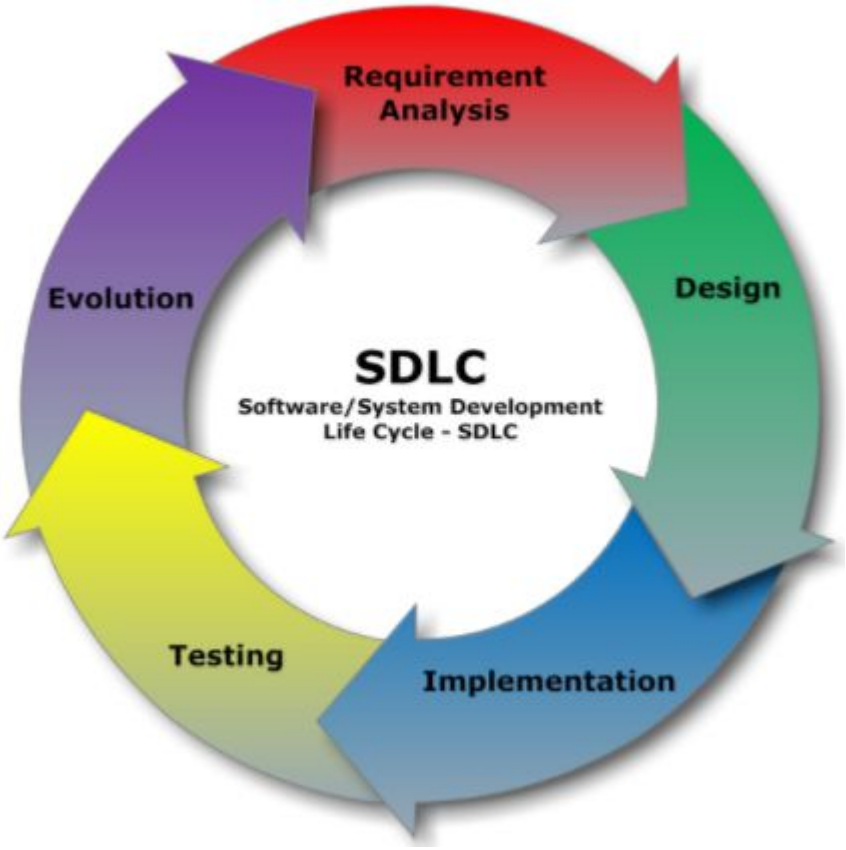


Figure 37 - Source: https://bit.ly/1LAj1A7

8.2.1 System requirements

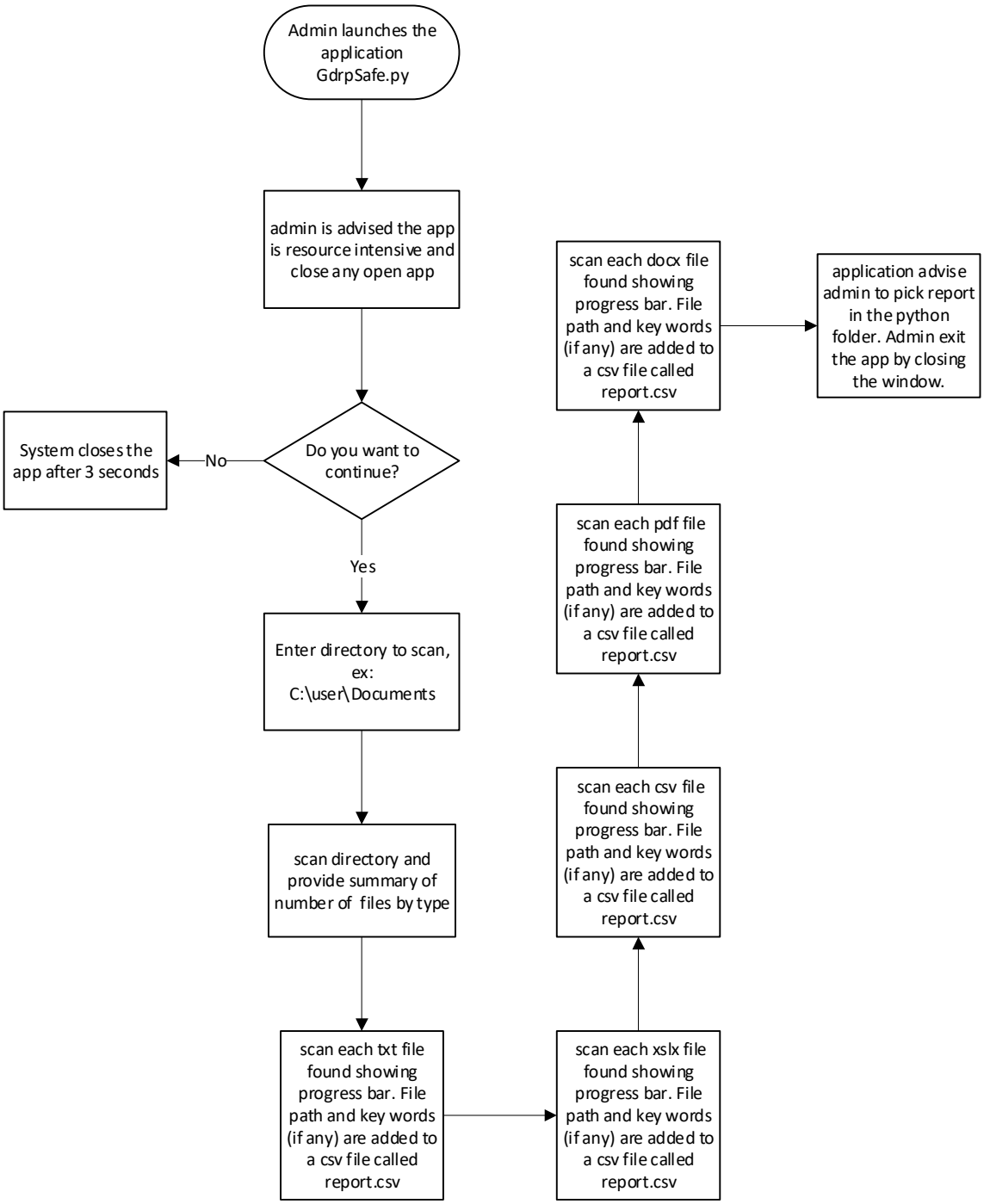
There are several text files with different extensions such as txt, docx, csv, xslx, pdf. Depending on the number of files stored in the hard drive, the application may be resource intensive since the script will open each document one by one and go through the full text seeking for key words relevant for the GDPR. The user is then asked if they want to proceed with files scanning. List of some key words is below:

```
#gdpr keywords

words = ["name", "surname", "first name", "second name", "maiden name",
"address", "passport", "driving license", "national id", "pps", "ppsn",
"social security number", "sex", "sexual", "phone", "health", "religion",
"photo", "genetic", "political", "straight", "gay", "bisex", "transex",
"orientation", "location", "ip address", "child", "kid", "coordinates",
"physical", "mental", "lgbt", "racial", "religious", "philosophical",
"trade union", "children", "biological", "biomedical", "medical", "diagnostic",
"physiology", "behaviour", "behavioural", "facial", "visual", "dactyloscopic",
"fingerprint", "disease", "disability", "risk", "clinical", "treatment",
"physiological", "physician"]
```

The user enters a directory they want to investigate. A first report on the screen give the user a summary of the number of files they have by extension. A progress bar will indicate the scanning status and the number of files scanned/remaining. A report in csv format that contains file directory and key words found in each file is created in the python directory.

8.2.2 Design



8.2.3 Implementation

The application is composed by 8 functions that are called one by one in the same order they were implemented. By the use of additional libraries to support read and write of text document, this application read the text and match it with any word relevant to the GDPR.

For instance, in the function to read text in pdf files, the most important part is the library "PyPDF2" of which there is a code snippet below:

```
pdfFile = open(pdfDoc, "rb") #rb, read in bynary mode
        pdfReader = PyPDF2.PdfFileReader(pdfFile)
        pdfPages = pdfReader.numPages
        for page in range(pdfPages):
            pObject = pdfReader.getPage(page)
            text = pObject.extractText()
```

Here the pdf file is open and each page read (`text = pObject.extractText()`), text is then compared with key words and if the latter matches, the key word is stored in a new variable:

```
if ((word in text) and (word not in keyWords)):
                    keyWords.append(word) #add key word to the list
```

Subsequently, the file path and keywords are written to the csv report file:

```
report = open("report.csv", "a", newline="")
        csvWriter = csv.writer(report)
        csvWriter.writerow(keyWords)
```

Other functions for txt, csv, docx and xslx documents, follow the same pattern although they use different libraries

8.2.4 Testing

Functional testing makes sure the system works correctly according to specifications.

Each function was immediately tested after coded. At the end there is a final testing to make sure all functions worked together and the application fulfils design and functional specifications.

A folder was created in "C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest" and there added some text files containing key words and some empty ones. Below there is an example of some text files and their relative sections where sensible data protected under the GDPR is visible:

- Web data like location, IP address, cookie data and RFID tags
- Identity information such as name, address and IDs
- Health and genetic data
- Biometric data
- Racial or ethnic data
- Political opinions
- Sexual orientation

Figure 38 – Section of document "Emilio-project(4).docx"

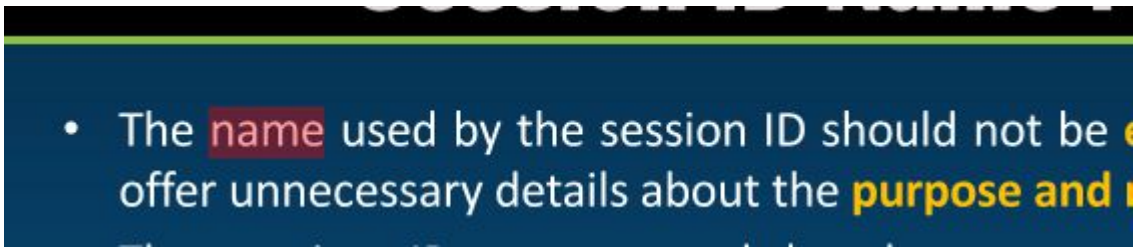


Figure 39 – Section of document "Application Security Lecture 5.pdf"

After performing the file scanner, those files and related words found are added to the CSV report:

C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\PDF\Application Security Lecture 4.pdf	name	fingerprint	physical	phone	address	risk									
C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\PDF\Application Security Lecture 5.pdf	address	name	fingerprint	phone											
C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\PDF\Lab 1 Network Security Analytics.pdf															
C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\PDF\Lab 2 OSSEC Installation and Configura	name	address	pps	behavior											
C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\PDF\pdfTest.pdf															
C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\word\Emilio project(3)-with-lit-rev-correcte	mental	name	photo	child	children	physical	address	genetic	location	physiological	orientation	sex	sexual	health	political
C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\word\Emilio project(4).docx	mental	name	photo	child	children	physical	address	genetic	location	physiological	orientation	sex	sexual	health	political

Figure 40 – Sample of report with file name and key words

Below are 2 screenshots of a completed scan and sample report:

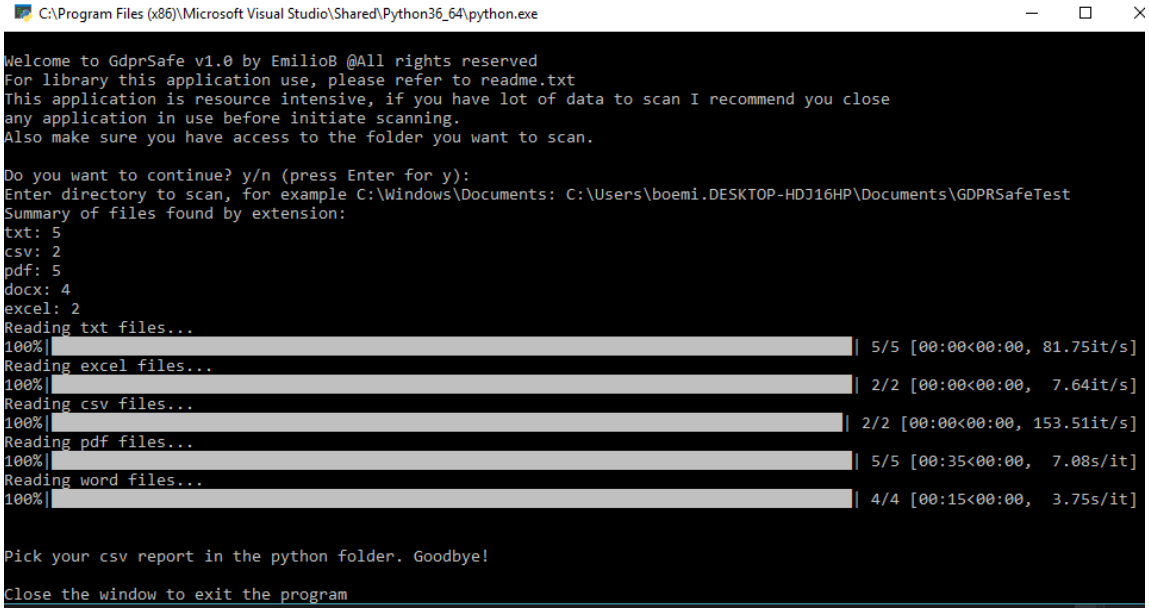
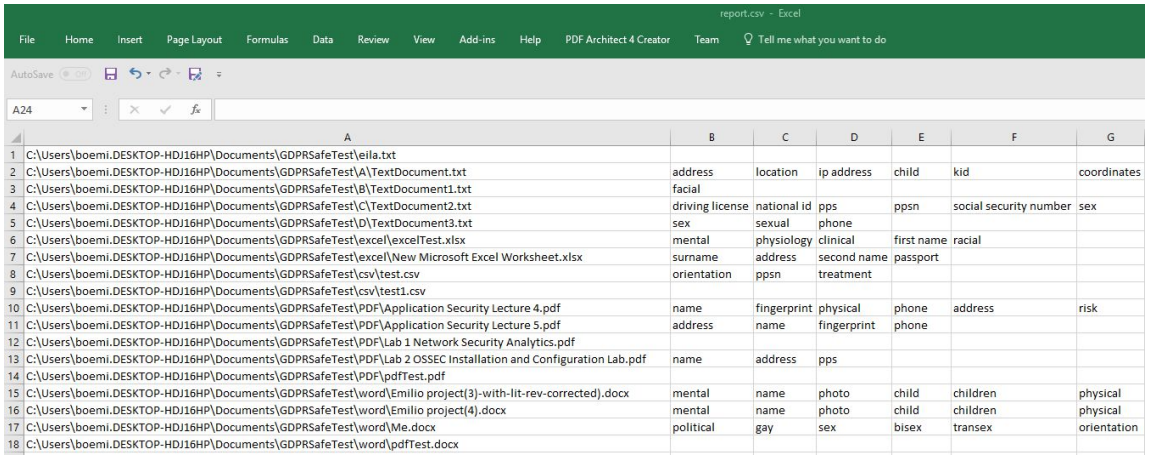


Figure 41 - Completed scan



	A	B	C	D	E	F	G
1	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\eila.txt						
2	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\A\TextDocument.txt	address	location	ip address	child	kid	coordinates
3	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\B\TextDocument1.txt	facial					
4	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\C\TextDocument2.txt	driving license	national id	pps	ppsn	social security number	sex
5	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\D\TextDocument3.txt	sex	sexual	phone			
6	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\excel\excelTest.xlsx	mental	physiology	clinical	first name	racial	
7	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\excel\New Microsoft Excel Worksheet.xlsx	surname	address	second name	passport		
8	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\csv\test.csv	orientation	ppsn	treatment			
9	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\csv\test1.csv						
10	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\PDF\Application Security Lecture 4.pdf	name	fingerprint	physical	phone	address	risk
11	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\PDF\Application Security Lecture 5.pdf	address	name	fingerprint	phone		
12	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\PDF\Lab 1 Network Security Analytics.pdf						
13	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\PDF\Lab 2 OSSEC Installation and Configuration Lab.pdf	name	address	pps			
14	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\PDF\pdfTest.pdf						
15	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\word\Emilio project(3)-with-lit-rev-corrected).docx	mental	name	photo	child	children	physical
16	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\word\Emilio project(4).docx	mental	name	photo	child	children	physical
17	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\word\Me.docx	political	gay	sex	bisex	transex	orientation
18	C:\Users\boemi.DESKTOP-HDJ16HP\Documents\GDPRSafeTest\word\pdfTest.docx						

Figure 42 - Sample report

8.2.5 Maintenance and evolution

Maintenance encompasses all those activities involved to improve the software over time. Organisations may request to add functionalities to applications to satisfy new business needs both in terms of revenue or to comply with new specifications. GdprSafe v1.0 is a basic application that offers a lot of scope for adding new functionalities and improving customer experience. The aim is to work on this app in the future to improve existing functionalities and add new ones.

Chapter 9: Conclusion

The focus of this project was to analyse the GDPR, a topic that is putting organisations under pressure for a deadline set for May 25th, 2018. It is still not clear how many firms have taken necessary steps towards compliance; how many are ready and how many are on the road for readiness.

The goal was twofold: a) prepare a comprehensive guide from a technical perspective to allow firms to have a big picture of the technology they use, some of their vulnerabilities and requirements for an adequate level of protection; b) provide means to initiate the process of data mapping to understand where data sensible for GDPR is located and who can access it.

There was also a personal goal set behind this project namely develop personal skills to be able to explain a technical topic to non-technical people.

Reviewing the document, it is clear the project met requirements in its whole. On the one hand, there is a comprehensive document indeed, with an initial explanation of GDPR with a comparison table of main changes and an overview of some of the common vulnerabilities of an online organisation and related countermeasures. Although the document handles technicalities, particular attention was paid to the style. As a result, topics are presented in an easy to read style to be a guide for technical and non-technical people.

On the other hand, the application provided is fully functional, easy to use and most importantly provide a report in csv format readable with Excel. Also, in this case the focus was to provide something that met requirements (locate data) and at the same time could provide further data analysis and manipulation. In fact, when the report is out this can be easily achieved using Excel data analytics features.

Appendix A: Glossary

Apache web server: an application used by the server to offer services and contents to the World Wide Web. Apache is an open source web server.

Backdoor: a system to bypass security for instance of a computer.

Bios: small software used by hardware systems to initialise the computer system after it is turned on.

Cloud Computing: a system of computers in a remote location that provide services such as storage to clients like mobile devices. Clients access cloud resources by the network connection.

Digital signature: encryption tool that allow the author to sign the document and give an invalid signature state to the receives if data has tampered.

Disaster Recovery Plan (DRP): business plan that document how to resume normal operations after a disaster.

DoS: denial of service. A client sends many requests to a server until the latter exhaust all resources and become unavailable.

Encryption: transform plain text in an unreadable and encoded format that cannot be read unless decryption key is known.

Forged link: a link for instance in an email that when clicked redirect the traffic to a malicious site instead to what it represented in written form.

Firewall: network security system that filters inbound and outbound traffic from a device such as laptop or server. It is commonly used to block malicious/unwanted traffic.

High availability: have two systems in place one active and one passive so if one is down the second takes over.

HTTP: Hyper Text Transfer Protocol, protocol used by the world wide web for formatting and transmission of messages.

HTTPS: secure version of HTTP, means data transmitted with this protocol is encrypted

Internet Protocol (IP): another fundamental protocol for internet communications that route information through the internet.

Least privilege: in a computer system least privilege allow for instance a person to access only information and resources to accomplish a specific task.

Mail server: a server used to send and receive emails.

Malware: malicious software.

Man in the middle: if Alice and Bob are communicating online, a man in the middle is someone that uses licit or illicit methods to sniffing communications between them.

Multi-Factor Authentication (MFA): identity a user and grant access to a system only after the user identified himself with 2 forms of authentication.

Penetration testing: a process to test vulnerabilities in a physical machine like a server.

Packet: contain data plus information to route data through the internet.

Port: is a connection an application uses to communicate with other peripherals.

Protocol: a set of rules for instance 2 devices used to communicate each other.

Root user: user with administrator privileges.

Security certificate: encryption tool that encrypt data in and out from a server in a server-client communication.

Server: a computer used to provide a service to a client such as browser.

Single Sign On (SSO): user authentication system that allow to use one set of credentials to access multiple services.

SSL (Secure Sockets Layer): standard technology to establish encrypted connections.

SQL database: a database is a way to organise data in a structured format and SQL is the language used for that purpose.

Transmission Control Protocol (TCP): a fundamental protocol for internet communications that. make a first connection between 2 devices such a computer and a server.

Transport Layer Security (TLS): successor of the SSL.

URL: is the web address of a website shown on the browser bar.

Virtual Private Network (VPN): a system that uses the public network to build a secure. communication channel to access private resources.

Web app testing: a process to test web application vulnerability.

List of References

Commission of The European Communities (2003) REPORT FROM THE COMMISSION First Report on the Implementation of the Data Protection Directive (95/46/EC) [online]. Available from: <http://aei.pitt.edu/45392/1/COM_(2003)_265_final.pdf> [accessed May 10, 2018].

Wong, R. (2012) The Data Protection Directive 95/46/EC: Idealisms and Realisms. International Review of Law, Computers & Technology. 26 (2), pp. 229-244.

Bessant, C 2015, 'The application of Directive 95/46/EC and the Data Protection Act 1998 when an individual posts photographs of other individuals online', European Journal Of Law & Technology, 6, 2, p. 1, Supplemental Index, EBSCOhost, accessed January 3, 2018.

Harris, EC 2007, 'PERSONAL DATA PRIVACY TRADEOFFS AND HOW A SWEDISH CHURCH LADY, AUSTRIAN PUBLIC RADIO EMPLOYEES, AND TRANSATLANTIC AIR CARRIERS SHOW THAT EUROPE DOES NOT HAVE THE ANSWERS', American University International Law Review, 22, 5, pp. 745-799, Business Source Complete, EBSCOhost, accessed January 5, 2018.

Hon, W.K., Millard, C., and Walden, I. Who is responsible for 'Personal Data' in Cloud Computing. available at http://papers.ssrn.com/sol3/papers.cfm?abstract_id=1783577; and Hon, W.K., Millard, C., and Walden, I. Who is responsible for 'Personal Data' in Cloud Computing? Part 2, available at http://papers.ssrn.com/sol3/papers.cfm?abstract_id=1794130, accessed January 5, 2018.

Poullet, Y., et al. 2011. Data protection in clouds. In Computers, privacy and data protection: an element of choice, S. Gutwirth et al., 1st ed., New York: Springer, pp. 377–409

Mantellaro, Alessandro 2012, Cloud computing, trans-border data flows and the European Directive 95/46/EC: applicable law and task distribution. European Journal of Law and Technology, [S.l.], v. 3, n. 2, oct. 2012. ISSN 2042-115X. Available at: http://ejlt.org/article/view/96/253, accessed Jan 10, 2018.

'INTERNET LAW -- PROTECTION OF PERSONAL DATA -- COURT OF JUSTICE OF THE EUROPEAN UNION CREATES PRESUMPTION THAT GOOGLE MUST REMOVE LINKS TO PERSONAL DATA UPON REQUEST' 2014, Harvard Law Review, 128, p. 735, LexisNexis Academic: Law Reviews, EBSCOhost, accessed January 2, 2018

Council Framework Decision 2008/977/JHA of 27 November 2008 on the protection of personal data processed in the framework of police and judicial cooperation in criminal matters (OJ L 350, 30.12.2008, pp. 60-71

Nino, M 2010, 'The protection of personal data in the fight against terrorism New perspectives of PNR European Union instruments in the light of the Treaty of Lisbon', Utrecht Law Review, 6, 1, pp. 62-85, Academic Search Complete, EBSCOhost, accessed January 4, 2018.

Van Eecke, P. 2017, EU Regulation [Homepage of DLA Piper], [Online]. Available: https://www.dlapiperdataprotection.com/index.html?t=eu-section&c=IE [Accessed January 10, 2018].

Intersoft Consulting, Art. 6 GDPR Lawfulness of processing. Available: https://gdpr-info.eu/art-6-gdpr/ [Accessed January 10, 2018].

Intersoft Consulting, Art. 5 GDPR Principles relating to processing of personal data. Available: https://gdpr-info.eu/art-5-gdpr/ [Accessed January 10, 2018].

Nadeau, M. 2016, General Data Protection Regulation (GDPR) requirements, deadlines and facts. Available: https://www.csoonline.com/article/3202771/data-protection/general-data-protection-regulation-gdpr-requirements-deadlines-and-facts.html [Accessed January 18, 2018].

Intersoft Consulting, Art. 9 GDPR Processing of special categories of personal data. Available: https://gdpr-info.eu/art-9-gdpr/ [Accessed January 10, 2018].

activeMind.legal (2018) GDPR Recital 58 [online]. Available from: <https://www.activemind.legal/legislation/gdpr/recital-58/> [Accessed May 03, 2018].

Intersoft Consulting, Art. 32 GDPR Security of processing. Available: https://gdpr-info.eu/art-32-gdpr/ [Accessed January 10, 2018].

Intersoft Consulting, Art. 37 GDPR Designation of the data protection officer. Available: https://gdpr-info.eu/art-37-gdpr/ [Accessed January 10, 2018].

Irvin, L. 2017, GDPR: Things to consider when processing biometric data. Available: https://www.itgovernance.eu/blog/en/gdpr-things-to-consider-when-processing-biometric-data/ [Accessed January 10, 2018].

Cloud Security Alliance (2017) Cloud Security Alliance Announces CSA Code of Conduct for GDPR Compliance [online]. Available from: <https://gdpr.cloudsecurityalliance.org/> [Accessed January 18, 2018].

Intersoft Consulting, Recital 159 Processing for scientific research purposes. Available: https://gdpr-info.eu/recitals/no-159/ and Recital 160 Processing for historical research purposes. Available: https://gdpr-info.eu/recitals/no-160/ [Accessed January 18, 2018]

Chassang, G 2017, The impact of the EU general data protection regulation on scientific research, Ecancermedicalscience, 11, 709-727, pp. 1-12, Academic Search Complete, EBSCOhost, accessed January 10, 2018.

Intersoft Consulting, Art. 83 GDPR General conditions for imposing administrative fines. Available: https://gdpr-info.eu/art-83-gdpr/ [Accessed January 18, 2018].

European Commission (2015) Agreement on Commission's EU Data Protection Reform Will Boost Digital Single Market [online]. Available from: <http://europa.eu/rapid/press-release_IP-15-6321_en.htm> [Accessed January 20, 2018.].

Margaret Rouse (2018) Confidentiality, Integrity, and Availability (CIA Triad) [online]. Available from: <https://whatis.techtarget.com/definition/Confidentiality-integrity-and-availability-CIA> [Accessed February 25, 2018].

Gemalto 2017, Biometrics: authentication and identification. Available: https://www.gemalto.com/govt/inspired/biometrics [Accessed February 10, 2018].

Armasu, L. 2017, Face ID Spoofed With 3D Printed Mask Sourced From 2D Photos. Available: http://www.tomshardware.co.uk/face-id-spoofed-3d-mask,news-57300.html [Accessed February 15, 2018].

Vincent Dail (2017) Facial Biometrics an Excellent Time Attendance and Tracking Option! [online]. Available from: <http://www.biometric-security-devices.com/facial-biometrics.html> [Accessed February 10, 2018].

Keith J. Hanna 2017, Method and system for biometric recognition, US 9646217 B2, USA.

Armasu, L. 2017, Face ID Spoofed With 3D Printed Mask Sourced From 2D Photos. Available: http://www.tomshardware.co.uk/face-id-spoofed-3d-mask,news-57300.html [Accessed February 10, 2018].

Lee, J. 2017, SensibleVision releases facial recognition security technology with liveness detection [Homepage of Biometric update.com], [Online]. Available: http://www.biometricupdate.com/201706/sensiblevision-releases-facial-recognition-security-technology-with-liveness-detection [Accessed February 10, 2018].

Jacobs, D. 2012, Biometric authentication methods: Comparing smartphone biometrics [Homepage of TechTarget], [Online]. Available: http://searchitchannel.techtarget.com/tip/Biometric-authentication-methods-Comparing-smartphone-biometrics [Accessed February 10, 2018].

Wikipedia (2018) Bring Your Own Device [online]. Available from: <https://en.wikipedia.org/w/index.php?title=Bring_your_own_device&oldid=839448329> [Accessed May 5, 2018].

Rouse, M. (2011) What is BYOD Policy? - Definition from WhatIs.Com [online]. Available from: <https://searchmobilecomputing.techtarget.com/definition/BYOD-policy> [Accessed May 5, 2018].

Beal, V. (2018) BYOD - Bring Your Own Device [online]. Available from: <https://www.webopedia.com/TERM/B/BYOD.html> [accessed May 5, 2018].

K. Downer and M. Bhattacharya, "BYOD Security: A New Business Challenge," 2015 IEEE International Conference on Smart City/SocialCom/SustainCom (SmartCity), Chengdu, 2015, pp. 1128-1133.

Sobers, A 2015, 'BYOD and the Mobile Enterprise - Organisational challenges and solutions to adopt BYOD', arXiv, EBSCOhost, Accessed 17 February 2018.

Hourani, N. (2018) When BYOD Goes Wrong: A Look Horror Stories and the Benefits of a Good Policy [online]. Available from: <https://www.liveconsulting.com/news/when-byod-goes-wrong-a-look-horror-stories-and-the-benefits-of-a-good-policy> [Accessed May 5, 2018].

M. Bartolozzi, P. Bellini, P. Nesi, G. Pantaleo and L. Santi, "A Smart Decision Support System for Smart City," 2015 IEEE International Conference on Smart City/SocialCom/SustainCom (SmartCity), Chengdu, 2015, pp. 117-122.

Wu M., R.C. Miller, G. Little, web wallet: preventing phishing attacks by revealing user intentions Proceedings of the second symposium on usable privacy and security, ACM (2006), pp. 102-113.

Rouse, M. (2014) What is Social Engineering? - Definition from WhatIs.Com [online]. Available from: <https://searchsecurity.techtarget.com/definition/social-engineering> [Accessed May 5, 2018].

Kaspersky Lab (2018) What is Social Engineering? | Definition | Kaspersky Lab US [online]. Available from: <https://usa.kaspersky.com/resource-center/definitions/social-engineering> [Accessed May 5, 2018].

Rouse, M. (2017) What is Phishing? - Definition from WhatIs.Com [online]. Available from: <https://searchsecurity.techtarget.com/definition/phishing> [Accessed May 5, 2018].

Aleroud, A, & Zhou, L 2017, 'Phishing environments, techniques, and countermeasures: A survey', Computers & Security, 68, pp. 160-196, ScienceDirect, EBSCOhost, Accessed March 3, 2018.

Holloway, m. (2015) Stuxnet Worm Attack on Iranian Nuclear Facilities [online]. Available from: <http://large.stanford.edu/courses/2015/ph241/holloway1/> [Accessed May 5, 2018].

Brecht, D. (2016) Spear Phishing: Real Life Examples [online]. Available from: <http://resources.infosecinstitute.com/spear-phishing-real-life-examples/#gref> [Accessed May 5, 2018].

Rouse, M. (2018) What is Corporate Area Network (CAN)? - Definition from WhatIs.Com [online]. Available from: <https://searchnetworking.techtarget.com/definition/corporate-area-network-CAN> [Accessed May 5, 2018].

Martin, J.A. (2018) What is Access Control? 5 Enforcement Challenges Security Professionals Need to Know [online]. Available from: <https://www.csoonline.com/article/3251714/authentication/what-is-access-control-5-enforcement-challenges-security-professionals-need-to-know.html> [Accessed May 5, 2018].

Infosec Institute (2018) Authentication, Authorization, and Access Control in Security+ [online]. Available from: <http://resources.infosecinstitute.com/category/certifications-training/securityplus/sec-domains/access-control-and-identity-management/authentication-authorization-and-access-control-in-security/> [Accessed May 5, 2018].

Velazquez, t. (2016) The Challenges and Benefits of Identity and Access Management [online]. Available from: <https://f5.com/resources/white-papers/the-challenges-and-benefits-of-identity-and-access-management-17862> [Accessed May 5, 2018].

Kerner, S.m. (2014) Two AT&T Data Breaches Draw Attention to Insider Access Issues [online]. Available from: <http://www.eweek.com/security/two-at-t-data-breaches-draw-attention-to-insider-access-issues> [Accessed May 5, 2018].

EB2BCOM (2018) Authorisation [online]. Available from: <http://www.eb2bcom.com/solutions/authorisation.html> [Accessed May 5, 2018].

Collins, K. (2017) The Hackers Who Broke into Equifax Exploited a Flaw in Open-Source Server Software. Quartz [online], September 8, Available from: <https://qz.com/1073221/the-hackers-who-broke-into-equifax-exploited-a-nine-year-old-security-flaw/> [Accessed May 5, 2018].

Acmetek (2018) What is an SSL Certificate? |SSL Certificates Benefits - Acmetek » [online]. Available from: <https://www.acmetek.com/ssl-certificates/> [Accessed May 5, 2018].

Microsoft (2018) Best Practices for Enforcing Password Policies [online]. Available from: <https://technet.microsoft.com/en-us/library/ff741764.aspx> [accessed May 5, 2018].

TechAdvisory.org (2017) Firewalls: Hardware Vs. Software [online]. Available from: <http://www.techadvisory.org/2017/03/firewalls-hardware-vs-software/> [Accessed May 5, 2018].

ONLINE TECH (2018) What is PCI Compliance?[online]. Available from: <http://www.onlinetech.com/resources/references/what-is-pci-compliance> [accessed May 5, 2018].

Zadelhoff, M.v. (2016) The Biggest Cybersecurity Threats are Inside Your Company [online]. Available from: <https://hbr.org/2016/09/the-biggest-cybersecurity-threats-are-inside-your-company> [Accessed May 5, 2018].

Tripwire (2017) Insider Threats as the Main Security Threat in 2017 [online]. Available from: <https://www.tripwire.com/state-of-security/security-data-protection/insider-threats-main-security-threat-2017/> [Accessed May 5, 2018].

Snowden, E. (2013) Edward Snowden: The Untold Story [online]. Available from: <https://www.wired.com/2014/08/edward-snowden/> [Accessed May 5, 2018].

Thudium, M. (2017) Insider Threat Statistics: 8 Convincing Findings [Infographic]. IT Security Central [online], June 30, Available from: <https://itsecuritycentral.teramind.co/2017/06/30/insider-threat-statistics-infographic/> [Accessed May 5, 2018].

Rijnetu, I. (2018) 9+ Free Encryption Software Tools to Protect Your Data [Updated 2018]. Heimdal Security Blog [online], March 13, Available from: <https://heimdalsecurity.com/blog/9-free-encryption-software-tools/> [Accessed May 5, 2018].

Wikipedia (2017) Hardware-Based Full Disk Encryption [online]. Available from: <https://en.wikipedia.org/w/index.php?title=Hardware-based_full_disk_encryption&oldid=807798307> [Accessed May 5, 2018].

Brunelli, M. (2017) Carbonite EVault Backup Solutions: Always on, always Up to Date [online]. Available from: <https://www.carbonite.com/blog/article/2017/04/carbonite-evault-backup-solutions-always-on-always-up-to-date/> [Accessed May 5, 2018].

IBM (2018) Global Data Centers for Your Global Business [online]. Available from: <https://www.ibm.com/cloud-computing/bluemix/data-centers#datacentermap> [Accessed May 5, 2018].

IBM (2018) IBM Cloud Direct Link [online]. Available from: <https://www.ibm.com/cloud/direct-link> [Accessed May 5, 2018].

Kinderhood Bank (2018) Consumer Online Banking Security [online]. Available from: <https://www.nubk.com/files/Consumer_Online_Banking_Security_Information.pdf> [Accessed May 5, 2018].

TutorialsPoint (2015) Systems Analysis and Design [online]. Available from: <http://www.tutorialspoint.com/system_analysis_and_design/system_analysis_and_design_tutorial.pdf> [Accessed May 5, 2018].